

Einführendes Labor zu Informations- und Cyber-Sicherheit

**Eindenken in die Welt
der Cyber Security mit
praktischen Beispielen**

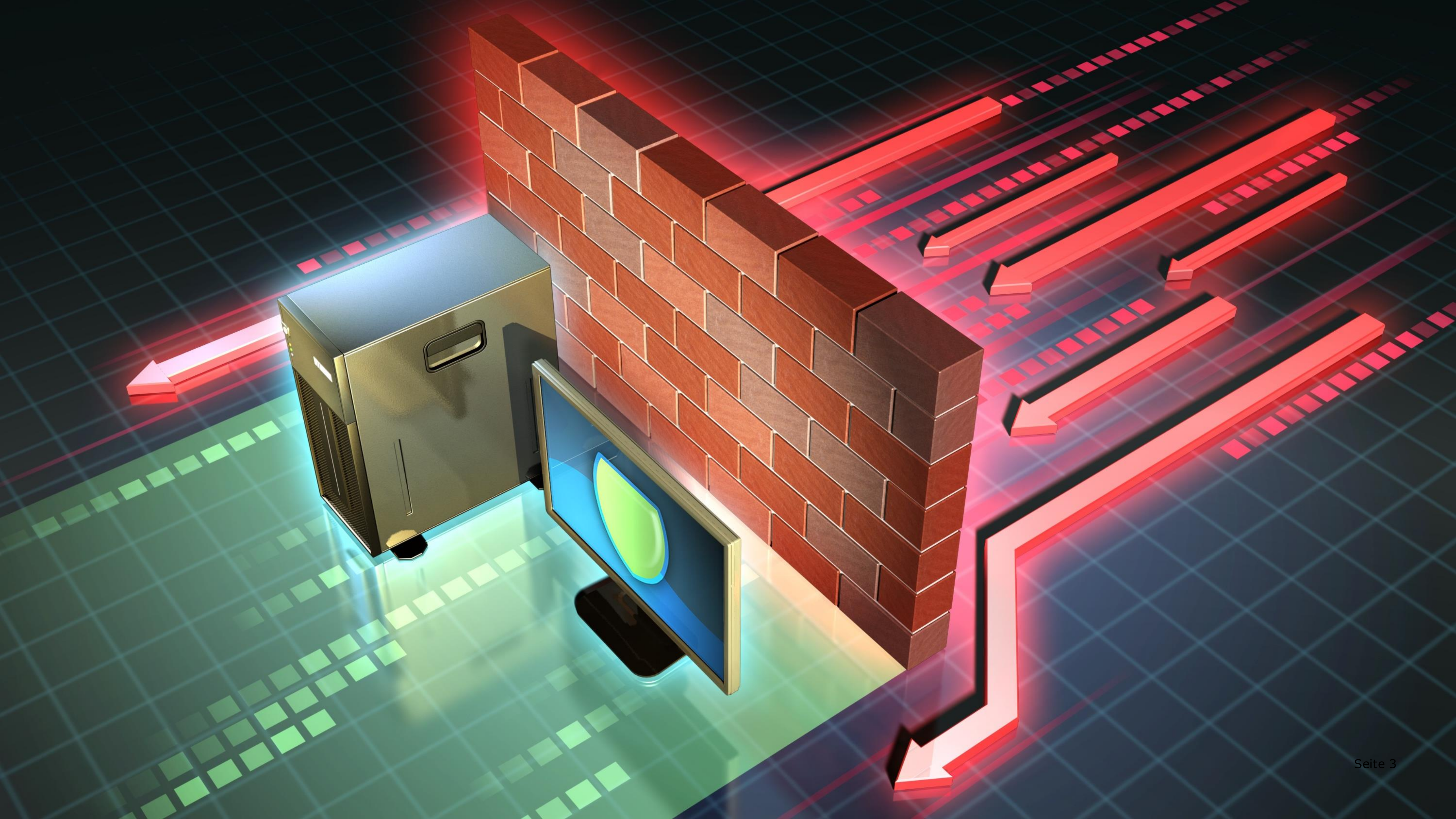
Informatik
10. November 2025

FH Zentralschweiz



Mikrofon- und Verständnis- Test





Organisatorisches

Informatik

10. November 2025

Modul: Einführendes Labor Sicherheit INTROL.H2501 - Semester-Agenda - Ablauf des Moduls – v20250902

SW1 – 15.09.	SW2 – 22.09.	SW3 – 29.09.	SW4 – 06.10.	SW5 – 13.10.	SW6 – 20.10.	SW7 – 27.10.
Einführung und Organisatorisches • ILIAS und Wochenplan • Aufbau der Vorlesung • Vorstellung der Modulinhalte • Besuch des Labors	Open Your Mind • SolarWinds-Hack • Def. Lateral Thinking • Zusammenhang zwischen Lateral Thinking und Cyber Security • Kreativitätstechniken und Fallbeispiele	Protokollanalyse • Protokolle & Schichten im Netzwerk • Ausgewählte Protokolle und Funktionen • Standards • Analyse mit Wireshark	Protokollanalyse-Lab • ARP, IP, ICMP, TCP & UDP, DNS & DHCP, HTTP & HTTPS und FTP-Protokoll • Analyse-Werkzeuge • Praktischer Umgang und Analyse	Web Authentication Lab • Grundlagen und Techniken zur Authentifizierung • Cookie-basierte Authentifizierung • OAuth 2.0 • WebAuthn	Man in the Middle (MitM) Lab • Unterschiedliche Arten von Man in the Middle (MitM)-Attacken • Methode: ARP Request Poisoning • Methode: DNS Spoofing	Internet Protocol Version 6 (IPv6) • Motivation: Warum? • IPv6-Adressierung • IPv6-Paket-Header • Spezial-IPv6-Adressen • Stateless Address Autoconfiguration • Andere Verfahren zur Adressvergabe
Theorie	Theorie	Theorie	Labor	Labor	Labor	Theorie
Zimmer: LS1A_402 Montag, 18:30 – 20:00 Uhr	Zimmer: LS1A_402 Montag, 18:30 – 20:50 Uhr	Zimmer: LS1A_402 Montag, 18:30 – 20:50 Uhr	Labor: LS1A_403 Montag, 18:30 – 20:50 Uhr	Labor: LS1A_403 Montag, 18:30 – 20:50 Uhr	Labor: LS1A_403 Montag, 18:30 – 20:50 Uhr	Zimmer: LS1A_402 Montag, 18:30 – 20:50 Uhr

SW8 – 03.11.	SW09 – 10.11.	SW10 – 17.11.	SW11 – 24.11.	SW12 – 01.12.	SW14 – 15.12.
IPv6 Lab • Analyse IPv6 • Reihenfolge der Nachrichten / Ablauf • Praktische Konfiguration • Tunnel- und IPv4/IPv6-Deployment-Szenarien	Firewall-Technologien • Definition Firewall • Vom Packetfilter zu Application Layer Gateways (ALGs) • Web Application Firewall (WAF) • Firewall-Architekturen	Firewall Basics Lab • Konfiguration und Funktionen von Firewalls • Schrittweises Kennenlernen der Funktionsweise & des technischen Ablaufs	Firewall Advanced Lab • Application Layer Gateways (ALGs) • Next Generation-Firewall (NextGen) • Einsatzgebiet und Funktionen	Password Cracking • Theorie der sicheren Passwörter • Salting • Windows VM-Passwort hacken	Physische Sicherheit • Von Schloss und Schlüsseln • Pick a lock: Lernen von Lockpicking-Techniken
Labor	Theorie	Labor	Labor	Labor	Theorie (Gastreferent)
Labor: LS1A_403 Montag, 18:30 – 20:50 Uhr	Zimmer: LS1A_402 Montag, 18:30 – 20:50 Uhr	Labor: LS1A_403 Montag, 18:30 – 20:50 Uhr	Labor: LS1A_403 Montag, 18:30 – 20:50 Uhr	Labor: LS1A_403 Montag, 18:30 – 20:50 Uhr	Zimmer: LS1A_402 Montag, 18:30 – 20:50 Uhr

Zoom-Link für Theorie-Sessions (Achtung: nur Streaming, kein Hybrid-Unterricht!):

<https://hslu.zoom.us/j/68994833813?pwd=BjrP7Xu9t0rU5SOJaPRSWP9F6qP3cr.1>

Heute

Labore Firewall & Firewall
Advanced
vor Ort

📁 07. Firewall-Technologien

Aktionen ▼

◀ Ebene hoch **Inhalt** Info Einstellungen Lernfortschritt Export Rechte

Labor nächsten Montag

Vorlesungsunterlagen

📁 1. Vorlesungsunterlagen

Tests



2. Vorbereitungsfragen zu Firewall (Basic)

Bitte beantworten Sie diese Fragen zu Hause als Vorbereitung auf die Laborübung. Sie müssen 90% der Antworten richtig beantworten, um die Prüfung zu bestehen. Bitte recherchieren und informieren Sie sich, um die Fragen zu beantworten und sich gut auf die Übung vorzubereiten. Geschätzter Zeitaufwand: ca. 30 min.

Lernfortschritt: ●■■■

Übungen



3. Laborübung - Firewall Basic

Abgabefrist: 21 Tage, 6 Stunden

Lernfortschritt: ■■■▶■

Vorbedingungen, die für einen Zugriff erfüllt werden müssen: » Anzeigen



Labor5 - Firewall Basics

pdf 9.5 MB Version: 17 2. Sep 2025, 14:21 Anzahl Seiten: 47

Vorbedingungen, die für einen Zugriff erfüllt werden müssen: » Anzeigen

Vorbereitungsfragen
ab heute

Unterlagen ab heute

07. Firewall-Technologien

Aktionen ▾

← Ebene hoch **Inhalt** Info Einstellungen Lernfortschritt Export Rechte

Labor nächsten Montag

Vorlesungsunterlagen

1. Vorlesungsunterlagen ▾

Tests

2. Vorbereitungsfragen ▾

Bitte beachten: Bitte lesen Sie sich gut auf die Übung vor. Vorbereitungsdauer: ca. 30 min.

Übungen

3. Laborübung - Firewall Basic ▾

Abgabefrist: 21 Tage, 6 Stunden

Lernfortschritt: 

Vorbedingungen, die für einen Zugriff erfüllt werden müssen: » Anzeigen

Labor5 - Firewall Basics ▾

pdf 9.5 MB Version: 17 2. Sep 2025, 14:21 Anzahl Seiten: 47

Vorbedingungen, die für einen Zugriff erfüllt werden müssen: » Anzeigen

Labordokument vor Labor bis nächste Woche anschauen und studieren.

Vorbereitungsfragen
ab heute

Unterlagen ab heute

Organisatorisches

- Laboraufgaben & Vorbereitung
- Zulassungsbedingungen für MEP (Testat)
 - *Abgabe der Laborberichte*
- Modulendprüfung: *Elektronische Prüfung*

➔ *Meldet euch via E-Mail, falls ein Labor noch aussteht!*

Modul: Einführendes Labor Sicherheit

Modulkürzel (Eventoname)	INTROL		I.BA_INTROL.19		
Gültigkeit & Status/Version	Gültig seit: H22		Valid 2.2 , 21.10.2022		
ECTS-Credits	3				
Durchführung	Wöchentlich; Herbst- & Frühlingssemester				
Unterrichtssprache	Deutsch				
Modulangebot Modultyp: K: Kernmodul P: Projektmodul E: Erweiterungsmodul M: Major-/Minormodul Z: Zusatzmodul	Dept.	Studiengang	Modultyp	Pflicht/Wahl	Major/Minor
	I	Information & Cyber Security	K	Pflicht	-

Modulverantwortliche/r	Wamser Florian, florian.wamser@hslu.ch		
Verantwortlicher Studiengang & -leiter	Information & Cyber Security: Hämmerli Bernhard, bernhard.haemmerli@hslu.ch		
Zwingende Modulvoraussetzungen		Bestanden	Besucht
	ISF_MM		x
	Und		
	NETW1_MM		x
	ISF_MM - Information Security Fundamentals, NETW1_MM - Networking 1		
Hinweise zu den Modulvoraussetzungen			
Zulassungsbedingungen für	1 Präsentation im Unterricht zum Thema Open Your Mind		

Modulendprüfung

Das Datum der Modulendprüfung steht fest:

- **Datum:** Freitag, 23.01.2026
- **Uhrzeit:** 13:30 bis 15:00 Uhr (Dauer etwa 1,5h)
- **Ort:** I.S1A_202
- **Art:** elektronisch im ILIAS
- Vergesst nicht einen Laptop mitzubringen. Kein iPad.
- Zur Sicherheit richtet bitte alle euer VPN ein, damit ihr im Zweifelfall über VPN auf den Test zugreifen könnt. KEINE externen DNS-Server nutzen.
- Zugelassen sind alle Unterrichtsmaterialien, Notizen, PDFs, Laborunterlagen aber *kein* Browser/Internet oder sonstige Online-Programme.
- Für die elektronische Prüfung vor Ort ist das Zeigen eines Ausweises zwingend notwendig.



ILIAS – Vorlesungsunterlagen & -material

Vorlesungsfolien



07a.Firewall_Grundlagen_v5

pdf 10,5 MB Heute, 17:02 Anzahl Seiten: 65



07b Firewall-Grundlagen (Cisco) v1.pdf (für interessierte Studenten, nicht prüfungsrelevant!)

pdf 2,2 MB Heute, 16:52 Anzahl Seiten: 40

Material



Next-Gen FW - McAfee Web Gateway - Webproxy-Regeln

png 2,2 MB 18. Aug 2023, 15:04



Next-Gen FW - McAfee Web Gateway - Webproxy-Regeln 2

png 2,0 MB 18. Aug 2023, 15:04



WAF - Airlock Web Application Firewall - Regeln für Verhinderung von SQL Injection

png 1,9 MB 18. Aug 2023, 15:04



WAF - Airlock Web Application Firewall - Regeln mit regulären Ausdrücken

png 1,4 MB 18. Aug 2023, 15:04



WAF - Airlock Web Application Firewall - Statistics für Korrektur von SQL Injection

png 1,2 MB 18. Aug 2023, 15:04



Next-Gen FW - Threatconnect - Bedrohungserkennung (Threat Detection)

png 948,6 KB 18. Aug 2023, 15:04



CheckPoint CheckMe-Portal

CheckMe führt einige simulierte Attacken auf dein Netzwerk aus, um deine aktuelle Firewall-Konfiguration zu testen.

Generelle Fragen & Feedback?

Informatik

10. November 2025





Firewall: Grundlagen

Schutz des Perimeters

Inhaltsübersicht

Firewall: Grundlagen – Schutz des Perimeters

1. Einführung: Firewall-Generationen
2. Application Layer Gateways (ALGs) & Proxies (Generation 3)
 - Next-Generation Firewalls
 - Web Application Firewalls
3. Firewall-Architekturen
4. Weitere Firewalls – Personal- und Linux-Firewalls



1. Einführung: Firewall-Generationen

Schutz des Perimeters

- Als Perimeter wird üblicherweise der Übergang zwischen *Internet* und *Intranet* bezeichnet, gemeint ist also das Bindeglied zwischen Firmennetzwerk und dem Internet bzw. dem ISP.
- *Rein funktional wird dafür eigentlich nur ein Router benötigt*, je nach Situation und Sicherheitsbedürfnis reicht das aber nicht und es werden deshalb *Paketfilter*, *Firewalls* oder *ALGs* eingesetzt.



Was ist eine Firewall?

Eine Firewall besteht aus

- mehreren Komponenten (Hardware und Software),
- wird zwischen zwei oder mehr Netzwerken eingesetzt und
- besitzt folgenden Eigenschaften:
 - Sämtlicher Datenverkehr durch die Firewall muss autorisiert werden → Firewall-Rules
 - Protokolle, welche die Firewall nicht versteht (z.B. SPX/IPX, AT, etc.), werden nicht weitergeleitet.
 - Sie selbst muss gegen Angriffe möglichst resistent sein.



Was ist eine Firewall?

Eine Firewall besteht aus

- mehreren Komponenten (Hardware und Software),
- wird zwischen zwei oder mehr Netzwerken eingesetzt und
- besitzt folgenden Eigenschaften:
 - Sämtlicher Datenverkehr durch die Firewall muss autorisiert werden → Firewall-Rules
 - Protokolle, welche die Firewall nicht versteht (z.B. SPX/IPX, AT, etc.), werden nicht weitergeleitet
 - Sie selbst muss gegen Angriffe möglichst resistent sein

Wikipedia: Sicherungssystem, das ein Rechnernetz oder einen einzelnen Computer vor unerwünschten Netzwerkzugriffen schützt.



Was kann eine Firewall (nicht)?

1. Eine Firewall kann nur Verbindungen schützen, die über sie laufen (→ Routing!?)
2. Eine Firewall kann nicht bzw. nur bedingt vor böartigen Insidern schützen
3. Eine Firewall wird bei einem erfolgreichen Angriff höchstwahrscheinlich keinen Alarm auslösen
4. Eine Firewall allein bietet keinen Schutz gegen das Versenden vertraulicher Dokumente und Informationen



Firewall-Historie

1980er Jahre: Anfänge der Netzwerksicherheit

- Erste Konzepte zur Kontrolle des Datenverkehrs zwischen Netzwerken.
- Fokus auf Paketfilterung zur Überwachung und Steuerung von Netzwerkpaketen.

1990er Jahre: Einführung der ersten Firewalls

- Erster grosser Zuwachs von Firmen und Organisationen mit Internet-Anschluss
- Schutz gegen nicht autorisierte Zugriffe vom externen Netz (d.h. primär vom Internet)
- Kommerzielle Verfügbarkeit von dedizierten Firewall-Lösungen.
- Einführung von Stateful Inspection für verbesserte Sicherheitskontrollen.

2000er Jahre: Weiterentwicklung hin zu Next-Generation Firewalls

- Integration von erweiterten Funktionen wie Anwendungsfilterung und Eindringungserkennung.
- Verbessertes User Identity Management und mehrschichtige Sicherheitsansätze.

2010er Jahre bis heute: Moderne Firewalls und Cloud-Sicherheit

- Anpassung an virtuelle Umgebungen und die Cloud.
- Einsatz von künstlicher Intelligenz (KI) und maschinellem Lernen zur Bedrohungserkennung.
- Vermehrte Fokussierung auf IoT-Sicherheit und Zero-Trust-Architekturen.



Firewall-Historie

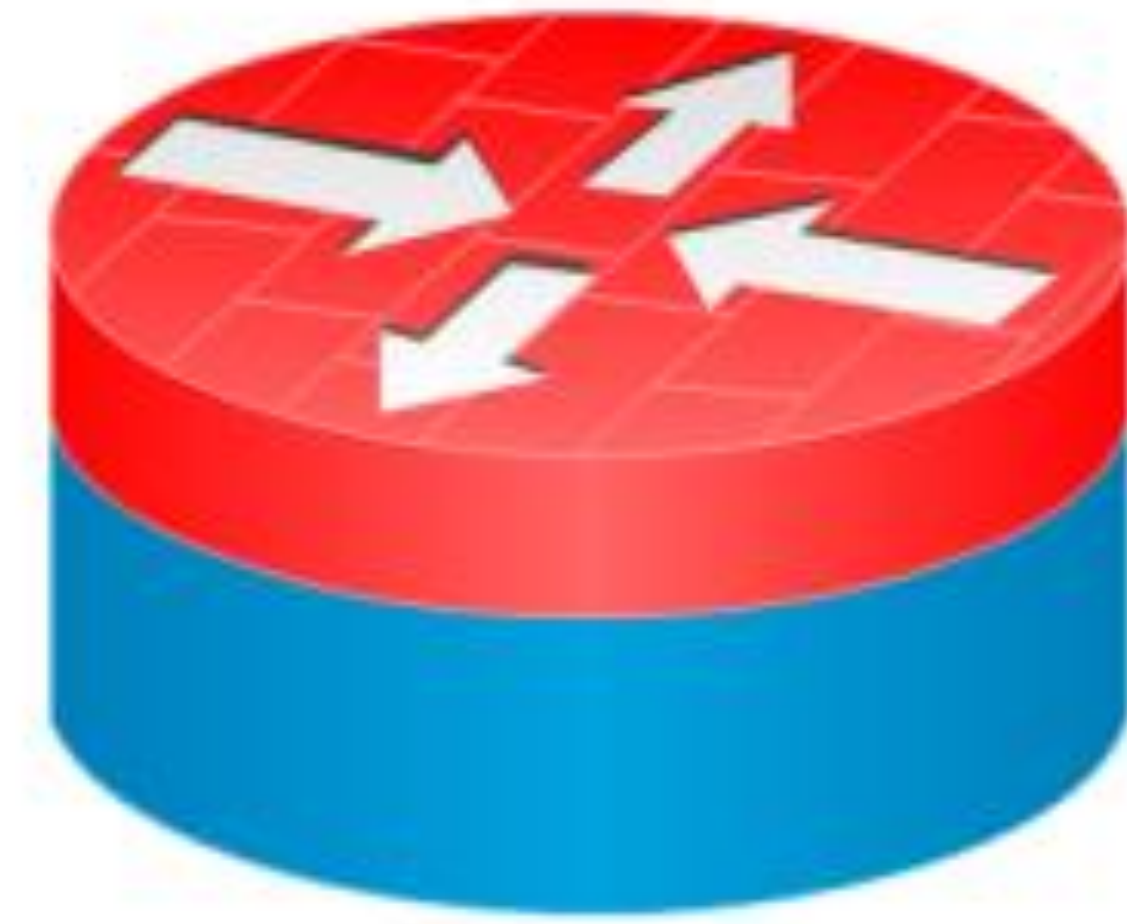
Oft wird zwischen den folgenden drei "Generationen" unterschieden:

1. **Packet Filters**
2. **Stateful Firewalls**
3. **Application Layer Gateway**

Manchmal wird sogar von 4. und 5. Generation gesprochen.

In Wirklichkeit gibt es keine solchen Bezeichnungen.

Seit ein paar Jahren wird (wieder) von "Next Generation Firewalls" gesprochen. (Bezeichnung gab es schon vor mehr als 15 Jahren!)



Router with firewall

Generation 1: Paketfilter

Paketfilter: die «ursprüngliche» Firewall

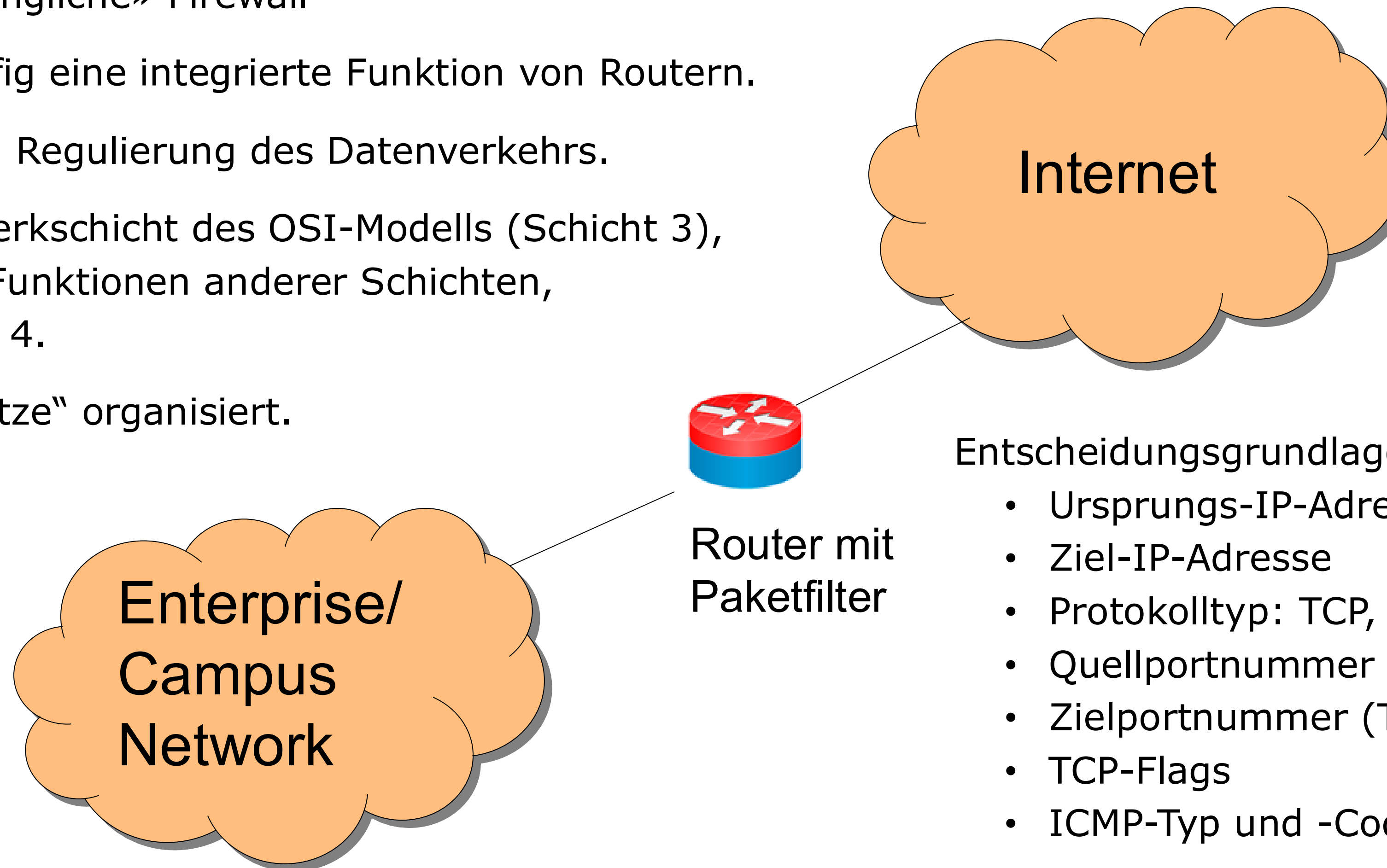
Paketfilterung war häufig eine integrierte Funktion von Routern.

Ziel: Überwachung und Regulierung des Datenverkehrs.

Arbeitet auf der Netzwerkschicht des OSI-Modells (Schicht 3), unterstützt aber auch Funktionen anderer Schichten, wie z. B. Schicht 2 und 4.

Regeln sind in „Filtersätze“ organisiert.

Jeder Filtersatz bearbeitet Verkehr über eine spezifische Schnittstelle zur Firewall.



Entscheidungsgrundlagen für Paketdurchlass:

- Ursprungs-IP-Adresse
- Ziel-IP-Adresse
- Protokolltyp: TCP, UDP, ICMP
- Quellportnummer (TCP/UDP)
- Zielportnummer (TCP/UDP)
- TCP-Flags
- ICMP-Typ und -Code

Die ersten Firewalls waren Router mit reinen Paketfiltern.

Paketfilter: Beispiel

Beispieldefinition einer ACL

Ziele

- ← Zugriff vom Internet ins interne Netz verboten
- Zugriff vom internen Netz ins Internet erlaubt

1^{ter} Versuch

- Abgehende Pakete erlaubt
- Ankommende Pakete verboten



Source IP	Source Port	Destinati on IP	Destinati on Port	Protocol	Flags	Action
Internal IP	Any	Any	Any	Any	Any	Allow
Any	Any	Internal IP	Any	Any	Any	Deny



Paketfilter

2^{ter} Versuch

- Ankommende TCP-Verbindungen verboten
- Abgehende TCP-Verbindungen erlaubt

Dieses Mal werden auch die TCP-Flags beachtet.

Probleme bestehen aber noch, z.B. werden die Portnummern nicht eingeschränkt.



Source IP	Source Port	Destinati on IP	Destinati on Port	Protocol	Flags	Action
Internal IP	Any	Any	Any	TCP	SYN	Allow
Any	Any	Internal IP	Any	TCP	SYN/ACK	Allow
Any	Any	Any	Any	TCP	ACK	Allow

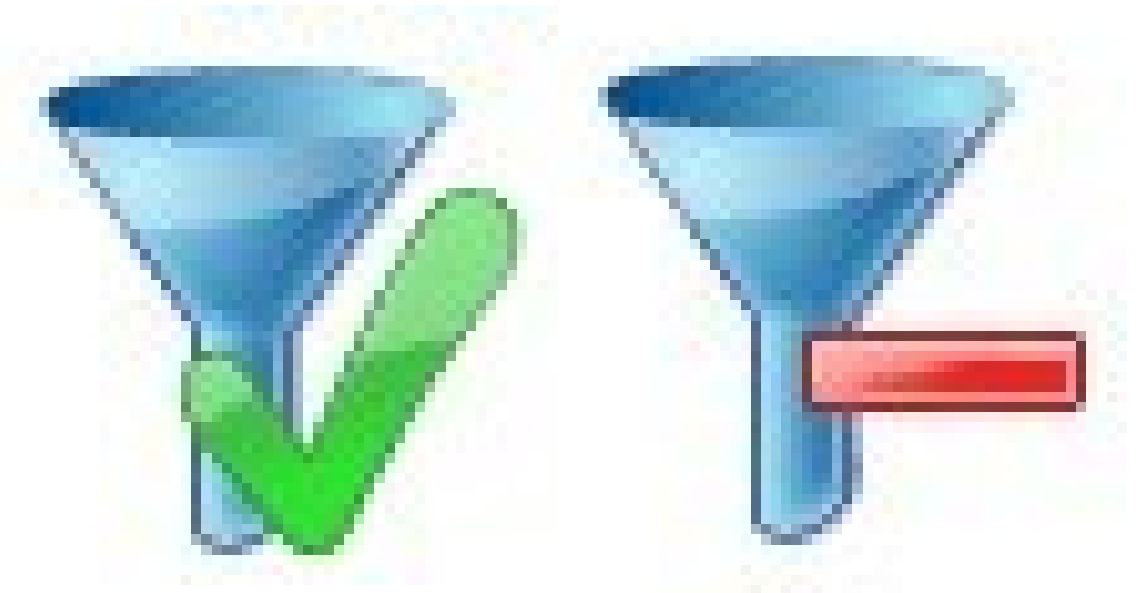
Paketfilter mit ACLs

Beispiel einer ACL die ICMP behandelt

```
Router#sh run | i access-list 150
access-list 150 remark ICMP ACL
access-list 150 remark Block fragmented ICMP packets
access-list 150 deny icmp any any fragments
access-list 150 remark Permit troubleshooting ICMP types
access-list 150 permit icmp any any echo
access-list 150 permit icmp any any echo-reply
access-list 150 permit icmp any any time-exceeded
access-list 150 permit icmp any any packet-too-big
access-list 150 remark Deny any other ICMP messages
access-list 150 deny icmp any any
access-list 150 remark Allow Other Traffic
access-list 150 permit ip any any
Router#
```

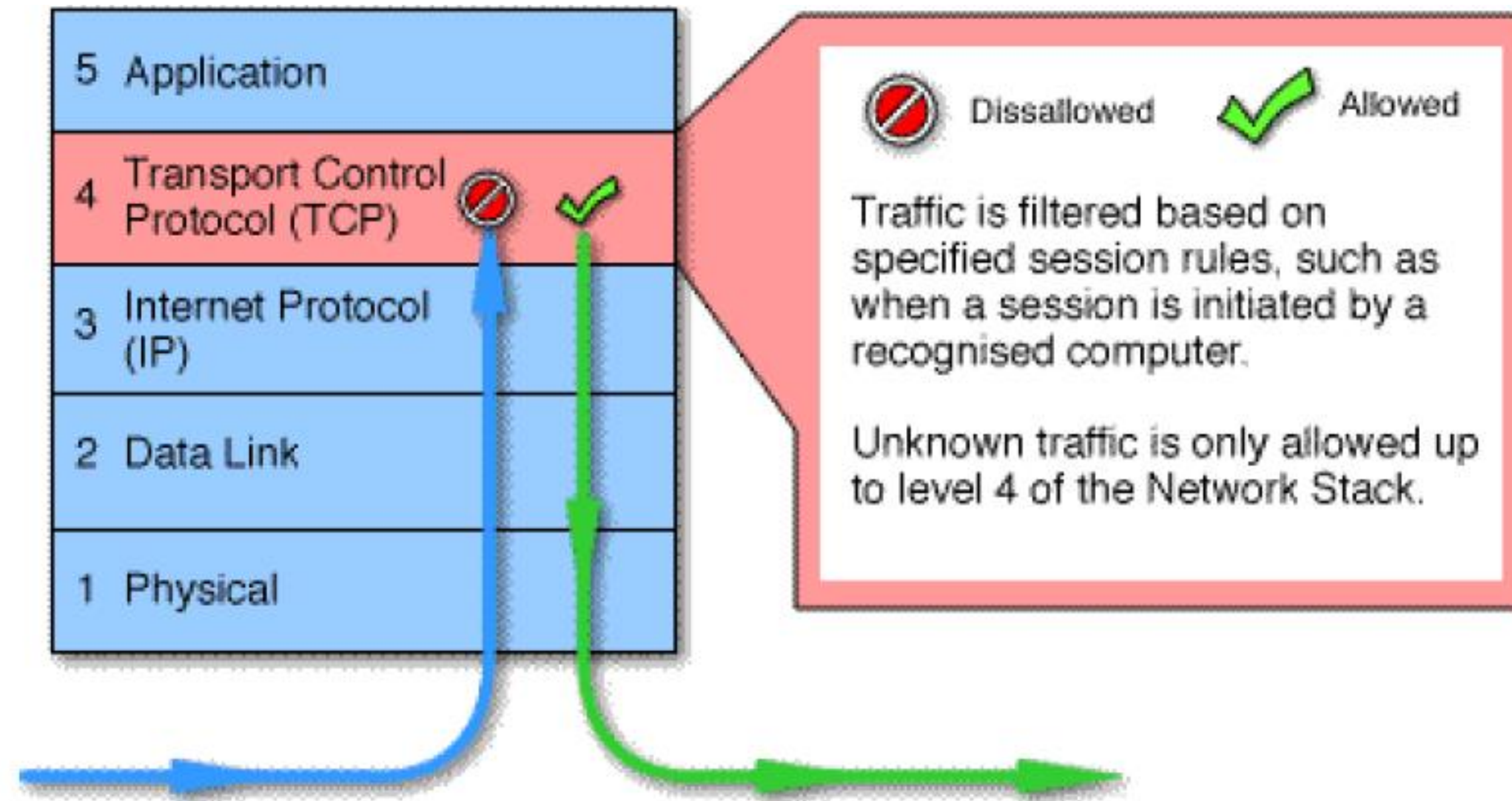

Nachteile von Paketfiltern

1. Schwierig zu konfigurieren
2. Probleme mit gewissen Protokollen wie FTP (ankommende Verbindung für FTP Data)
3. Jedes Paket wird einzeln kontrolliert (keine Zusammenhänge zu vorhergehenden Paketen)
4. Probleme mit Protokollen mit dynamischen Port-Nummern
5. Probleme mit bestimmten Angriffsarten wie z.B.
 - Pakete mit Source Port 20 (TCP) oder 53 (TCP/UDP)
 - Pakete mit gefälschter Source IP-Adresse
 - TCP-ACK-Paket ohne vorhergehendes SYN
6. Paket-Inhalt (Daten) wird NICHT kontrolliert!



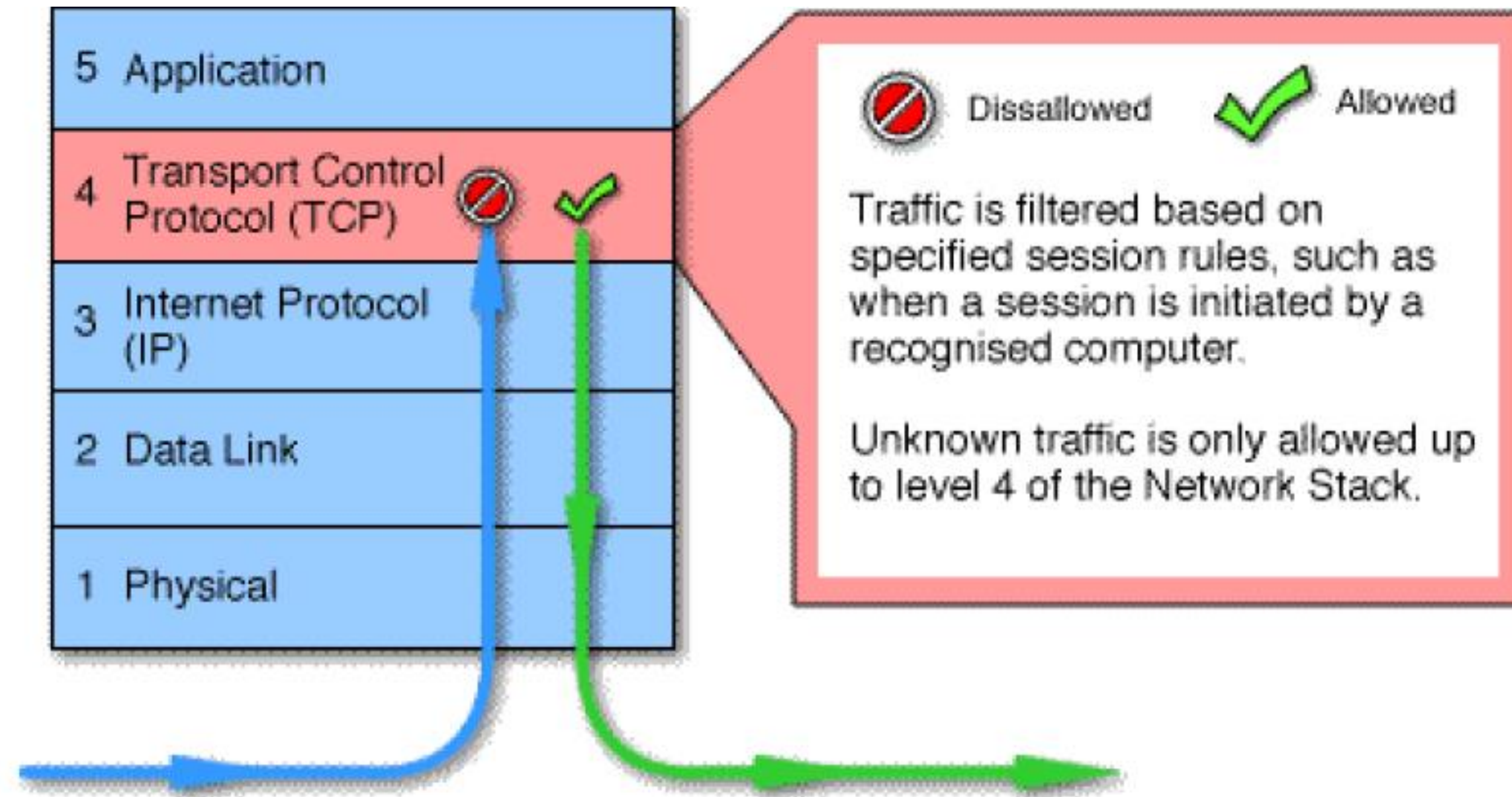
Generation 2: Stateful Inspection FW

- Paketfilter mit "Intelligenz"
- Zusammenhänge zwischen Paketen werden berücksichtigt ("Stateful" im Vergleich zu "Stateless" wie bei Paketfilter)



Stateful Inspection FW

- Ports können bei Bedarf dynamisch geöffnet / geschlossen werden
- Kein Problem mehr mit bestimmten Angriffsarten wie z.B.
 - TCP-Pakete mit Source Port 20 (bei FTP)
 - TCP ACK Paket ohne vorherige SYN (*)
- Kein Problem mehr mit FTP
- Kein Problem mit Protokollen die dynamische Port-Nummern verwenden



Stateful Inspection Firewall: Beispiel

«real-life»-Beispiel (Ausschnitt) eines Firewall-Rulesets einer Stateful-Firewall

System

Router

Policy & Objects

Policy

IPv4

DoS

Multicast

Local In

Central NAT

Proxy Options

SSL/SSH Inspection

Objects

Monitor

Create New Edit Delete

Section View Global View

Search

Seq.#	Source	Destination	Schedule	Service	Action	NAT	Log
lan - port2 (PPosten) (13 - 13)							
lan - TelefonNet (14 - 14)							
lan - wan1 (TEP-Internet) (15 - 21)							
15	ebexchange	extIP_...Mail1 extIP_...Mail2	always	ALL	ACCEPT	Enable	All
16	GdeAPP	all	always	ALL	ACCEPT	Enable	UTM
17	Intranet_DHCP_Range	Microsoft	always	HTTP HTTPS	ACCEPT	Enable	UTM
18	Intranet_DHCP_Range Local_Internet_Access	all	always	HTTP HTTPS	ACCEPT	Enable	All
19	Protonet	all	always	ALL	ACCEPT	Enable	UTM
20	Intranet_LAN	all	always	NTP	ACCEPT	Enable	
21	Intranet_Fix1_Range Intranet_Fix2_Range	all	always	ALL	ACCEPT	Enable	



Regelaufbau: Whitelisting & Drop Rule

Access Rules (WAN > LAN)

Items 1 to 4 (of 4)

View Style:

All Rules

Matrix

Drop-down Boxes

View IP Version:

IPv4 Only

IPv6 Only

IPv4 and IPv6

Show Unused Zones

Hide Disabled Rules

Add...

Delete

Clear Statistics

Restore Defaults...

#	From	>	To	Priority	Source	Destination	Service	Action	Users Ind.	Users Excl.	Flow Report	Geo-IP Filter	Botnet Filter	Packet Monitor	Comment	Enable	Configure
1	WAN	>	LAN	1	[redacted]	WAN Primary IP	[redacted]	Allow	All	None		✓	✓			✓	[stats][edit][delete]
2	WAN	>	LAN	2	Any	WAN Primary IP	[redacted]	Allow	All	None		✓	✓			✓	[stats][edit][delete]
3	WAN	>	LAN	3	[redacted]	WAN Primary IP	SERVER Services	Allow	All	None		✓	✓			✓	[stats][edit][delete]
4	WAN	>	LAN	4	Any	Any	Any	Deny	All	None						✓	[stats][edit][delete]

Add...

Delete

Clear Statistics

Restore Defaults...

Übersicht über Firewall-Generationen

Generation 1: Paketfilter

Generation 2: Stateful Inspection FW

Generation 3: Application-Layer Gateway (ALG)

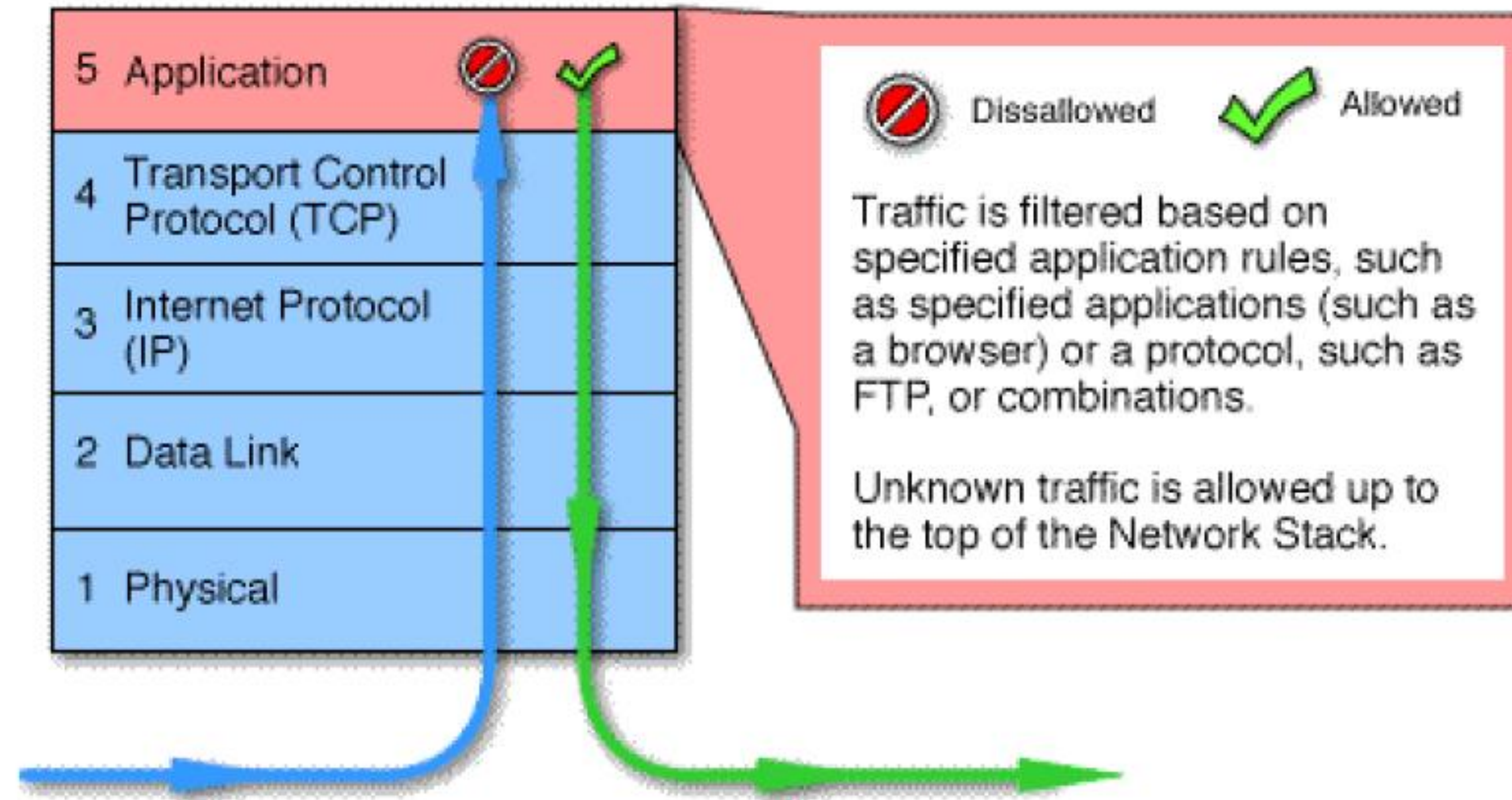
- Web Application Firewalls (WAF)
- Next-Generation Firewall (NGFW)

2. Application Layer Gateways (ALGs) & Proxies (Generation 3)

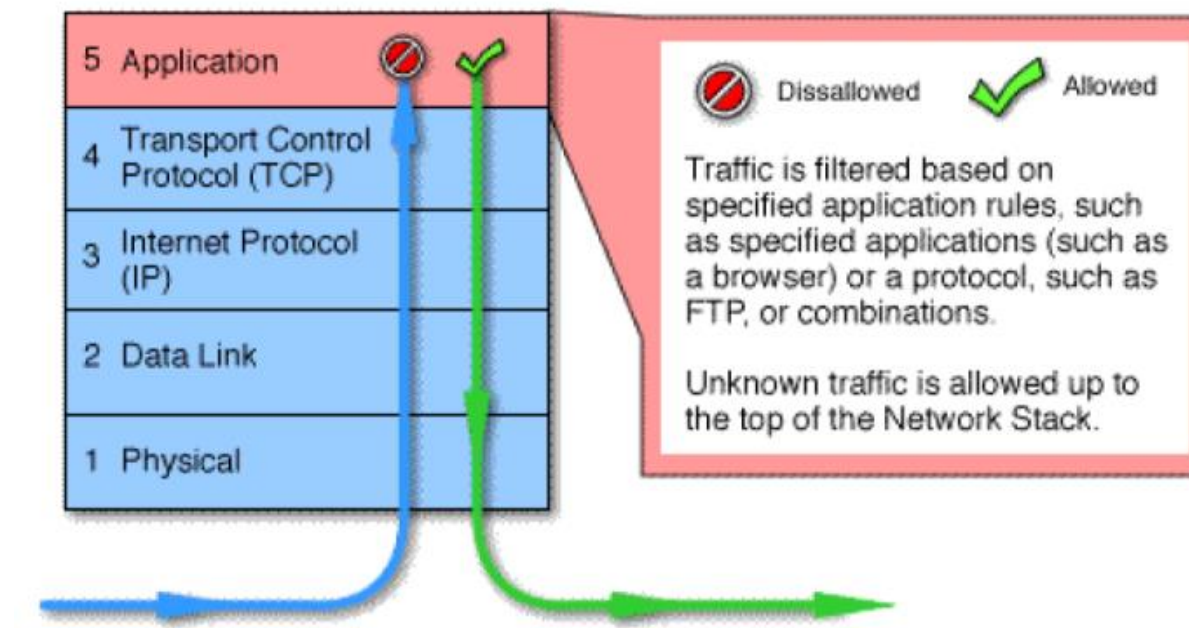
Generation 3: Application Layer Gateways

Werden auch «Proxy» genannt

Proxy ≡
Stellvertreter



Application Layer Gateways



Vorteile

- Einfacher zu konfigurieren im Vergleich zum Paket Filter. Keine vertiefte TCP/IP Kenntnisse erforderlich.
- Keine direkte Netzverbindung vom Internet ins interne Netz.
- Keine Probleme mit bestimmten Angriffsarten wie z.B.
 - TCP Pakete mit Source Port 20
 - TCP ACK Paket ohne vorherige SYN
- Relativ sicher im Vergleich zu Packet Filter.

Nachteile

- Relativ langsam im Vergleich zum Paket Filter.
- Unterstützung für gängige Netzwerk-Protokolle wie ftp, telnet, smtp usw. Falls neue oder nicht unterstützte Protokolle verwendet werden sollen, muss eine neue Firewall-Software entwickelt werden.

ALG-Beispiel (Proxy)

BLUE COAT ProxySG 300-5
Management Console
S/N 1711164155 SGOS 6.7.3.6 Proxy Edition

Home Documentation Support Launcher

Statistics Configuration Maintenance Health: OK

General
Identification
Clock
Archive
Network
ADN
Services
Proxy Services
Management Services
Clients
SSL
Proxy Settings
Bandwidth Mgmt.
Authentication
Content Filtering
Application Classification
Geolocation
Threat Protection
Content Analysis

Proxy Services Static Bypass List Restricted Intercept List

Force Bypass
☐ Temporarily bypass all proxy services

Service	Destination	Action
DNS	All -> All:53	Bypass
Endpoint Mapper	All -> All:135	Bypass
Explicit HTTP		
All -> Explicit:8080		Intercept
All -> Explicit:80		Bypass
External HTTP	All -> Transparent:80	Intercept
FTP	All -> All:21	Bypass
HTTPS	All -> Explicit:443	Bypass
Internal HTTP		

Blue Coat Visual Policy Manager

File Edit Policy Configuration View Help

Add rule Delete rule(s) Move up Move down Install policy

Cacheing SSL Intercept Proxy Admin Authentication Proxy Admin Access Web Authentication WebAccess BlackList WebAccess WhiteList Antivirus ICAPFee...

No.	Source	Destination	Service	Time	Action	Track	Comment
1	Any	G_Melani	Any	Any	Force Deny	None	
2	Any	G_Global_BlackList	Any	Any	Force Deny	None	
3	G_ITA_Hosts	Any	Any	Any	Allow	None	
4	G_ITA_Users	Any	Any	Any	Allow	None	
5	G_Linux-Team-PC	Any	Any	Any	Allow	None	
6	G_Linux-Team-User	Any	Any	Any	Allow	None	
7	Any	Any	Any	Any	Deny	None	

Settings retrieved from SG Appliance

All rights reserved.

100%

Proxies können neben den "klassischen" Parametern auch User oder Clientsoftware im Ruleset integriert

ALG: Next-Generation Firewalls ("NGFW")

Informatik

10. November 2025

Moderne Firewalls: NGFW

Ich verwende den Begriff Next-Gen FW nur ungern weil er uralt ist!

- Eine moderne Firewall (NGFW) ist ein System (Software und ev. Hardware), welches auch ausgefeilte Angriffe erkennen und blockieren kann.
- Dazu werden Sicherheitsrichtlinien sowohl auf dem Applikations-Layer als auch auf dem Port- und Protokoll-Level eingesetzt.
- Sie fassen drei Schlüsselfunktionen zusammen
 - Techniken von professionellen (stateful) Firewalls,
 - Intrusion Detection & Prevention Systemen (IDP & IPS)
 - Applikations-Kontrolle (mittels Deep-Packet-Inspection)



Moderne Firewalls: NGFW

- NGFWs können etwa
 - Details zum Datenverkehr einer Web-Applikation liefern und
 - die Zugriffe blockieren, wenn ein bekanntes Exploit zum Angriff ansetzt.
- Sie kombinieren die Funktionalitäten herkömmlicher Firewalls darunter
 - Paketfilterung,
 - Network Address Translation (NAT),
 - URL-Blockierungmit modernen Funktionalitäten
 - Intrusion Detection & Prevention,
 - SSL und SSH Inspection,
 - Deep-Packet-Inspection,
 - Reputations-basierte Malware-Abwehr oder
 - Applikations-Awareness.

Application Awareness

patto NETWORKS

Dashboard ACC Monitor Policies **Objects** Network Device

Commit Config Search

Help

Search All 2620 matching applications

Category ▲	Subcategory ▲	Technology ▲	Risk ▲	Characteristic ▲
810 business-systems	51 audio-streaming	1021 browser-based	926 1	629 Evasive
604 collaboration	22 auth-service	1098 client-server	692 2	628 Excessive Bandwidth
444 general-internet	36 database	364 network-protocol	504 3	360 Prone to Misuse
289 media	81 email	135 peer-to-peer	359 4	651 SaaS
471 networking	63 encrypted-tunnel		139 5	1190 Transfers Files
2 unknown	47 erp-crm			369 Tunnels Other Apps
	314 file-sharing			315 Used by Malware
	64 gaming			1616 Vulnerability
	165 general-business			1299 Widely used

Name	Tagged	Category	Subcategory	Risk	Technology	Standard Ports
☐ 100bao		general-internet	file-sharing	5	peer-to-peer	tcp/3468,6346,11300
☐ iec-60870-5-104						
☐ 104apci-supervisory		business-systems	management	2	client-server	tcp/2404
☐ 104apci-unnumbered		business-systems	management	2	client-server	tcp/2404
☐ 104asdu-file-transfer		business-systems	management	3	client-server	tcp/2404
☐ 104asdu-param-control		business-systems	management	2	client-server	tcp/2404
☐ 104asdu-process-control		business-systems	management	2	client-server	tcp/2404

URL Filtering

patato NETWORKS

DashboardACCMonitorPoliciesObjectsNetworkDevice

CommitConfigSearch

Help

Addresses

Address Groups

Regions

Applications

Application Groups

Application Filters

Services

Service Groups

Tags

GlobalProtect

- HIP Objects
- HIP Profiles

External Dynamic Lists

Custom Objects

- Data Patterns
- Spyware
- Vulnerability
- URL Category

Security Profiles

- Antivirus
- Anti-Spyware
- Vulnerability Protection

2 items

	Name	Location	Block List	Action for Block List	Allow List	Site Access	User Credential Submission
☒	default	Predefined		block		Allow Categories (57) Alert Categories (0) Continue Categories (0) Block Categories (9) Override Categories (0)	Allow Categories (66) Alert Categories (0) Continue Categories (0) Block Categories (0)
☐	Wlan-Blueair-Guest		ifolder.ru 360vield.com	block		Allow Categories (58) Alert Categories (0)	Allow Categories (56) Alert Categories (0)

URL Filtering Profile (Read Only)

Name: default

Description:

Categories

Overrides

URL Filtering Settings

User Credential Detection

66 items

Category	Site Access	User Credential Submission
☐ abusead-drugs	DIOCK	DIOCK

Content Awareness

Service Groups

Tags

GlobalProtect

HIP Objects

HIP Profiles

External Dynamic Lists

Custom Objects

Data Patterns

Spyware

Vulnerability

URL Category

Security Profiles

Antivirus

Anti-Spyware

Vulnerability Protection

URL Filtering

File Blocking

WildFire Analysis

Data Filtering

DoS Protection

Security Profile Groups

Log Forwarding

Authentication

Decryption Profile

Schedules

☐			Log all other file types	any	any	both	alert
☒	strict file blocking	Predefined	Block all risky file types	any	7z, bat, cab, chm, class, cpl, dll, exe, flash, hlp, hta, msi, Multi-Level-Encoding, ocx, PE, pif, rar, scr, tar, torrent, vbe, wsf	both	block
			Continue prompt encrypted files	any	encrypted-rar, encrypted-zip	both	block
			Log all other file types	any	any	both	alert

File Blocking Profile (Read Only)

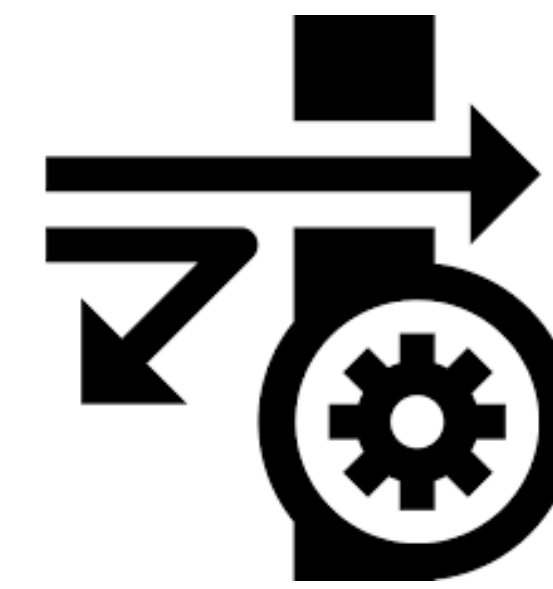
Namebasic file blocking

Description

3 items

☐	Name	Applications	File Types	Direction	Action
☒	Block high risk file types	any	7z bat chm class cpl dll exe hlp	both	block

In einem Ruleset verknüpft



Type	Source				Destination		Application	Service	Action	Profile
	Zone	Address	User	HIP Profile	Zone	Address				
interzone	Z_YellowNet	any	any	any	Z_untrust	any	any	any	Allow	
interzone	Z_Core	G_IT-Adminserver	any	any	Z_vlan312_Z...	vlan312_ZentraleDien...	any	tcp-any	Allow	none
interzone	Z_Core	P_10	any	any	Z_vlan312_Z...	vlan312_ZentraleDien...	capwap icmp radius radius-dyna...	application-default	Allow	none
interzone	Z_Core	P_10	any	any	Z_vlan312_Z...	vlan312_ZentraleDien...	any	P_1700-udp service-http service-https	Allow	none
interzone	Z_Core	G_IT-Adminserver	any	any	Z_vlan312_Z...	vlan312_ZentraleDien...	ssh	application-default	Allow	none
interzone	Z_Core	G_ITA-Members	any	any	Z_vlan312_Z...	vlan312_ZentraleDien...	any	P_7000	Allow	none
interzone	Z_Core	G_ITA-Members	any	any	Z_vlan312_Z...	G_WLC	any	snmp snmp-trap	Allow	none
interzone	Z_Core	G_SUSE-migr	any	any	Z_vlan312_Z...	vlan312_ZentraleDien...	any	P_http-pxe	Allow	none
interzone	Z_Core		any	any	Z_vlan312_Z...		dns	application-default	Allow	none
interzone	Z_Core		any	any	Z_vlan312_Z...		any	P_G-Infoblox-failover-tcp P_Infoblox-failover-udp	Allow	none
interzone	Z_Core	any	any	any	Z_vlan312_Z...		dhcp dns	application-default	Allow	none
interzone	Z_Core	G_IT-windows-admin	any	any	Z_vlan314_A...	G_windows-pc-client...	ms-rdp	application-default	Allow	none
interzone	Z_Core	G_Servview-new	any	any	Z_vlan314_A...	vlan314_admin	snmp	application-default	Allow	none
interzone	Z_Core	G_Servview-new	any	any	Z_vlan314_A...	vlan314_admin	any	P-G_Servview P_Servview-udp service-http service-https	Allow	none
interzone	Z_Core	G_IT-Adminserver	any	any	Z_vlan314_A...	vlan314_admin	ms-rdp	application-default	Allow	none

ALG: Web Application Firewalls ("WAF")

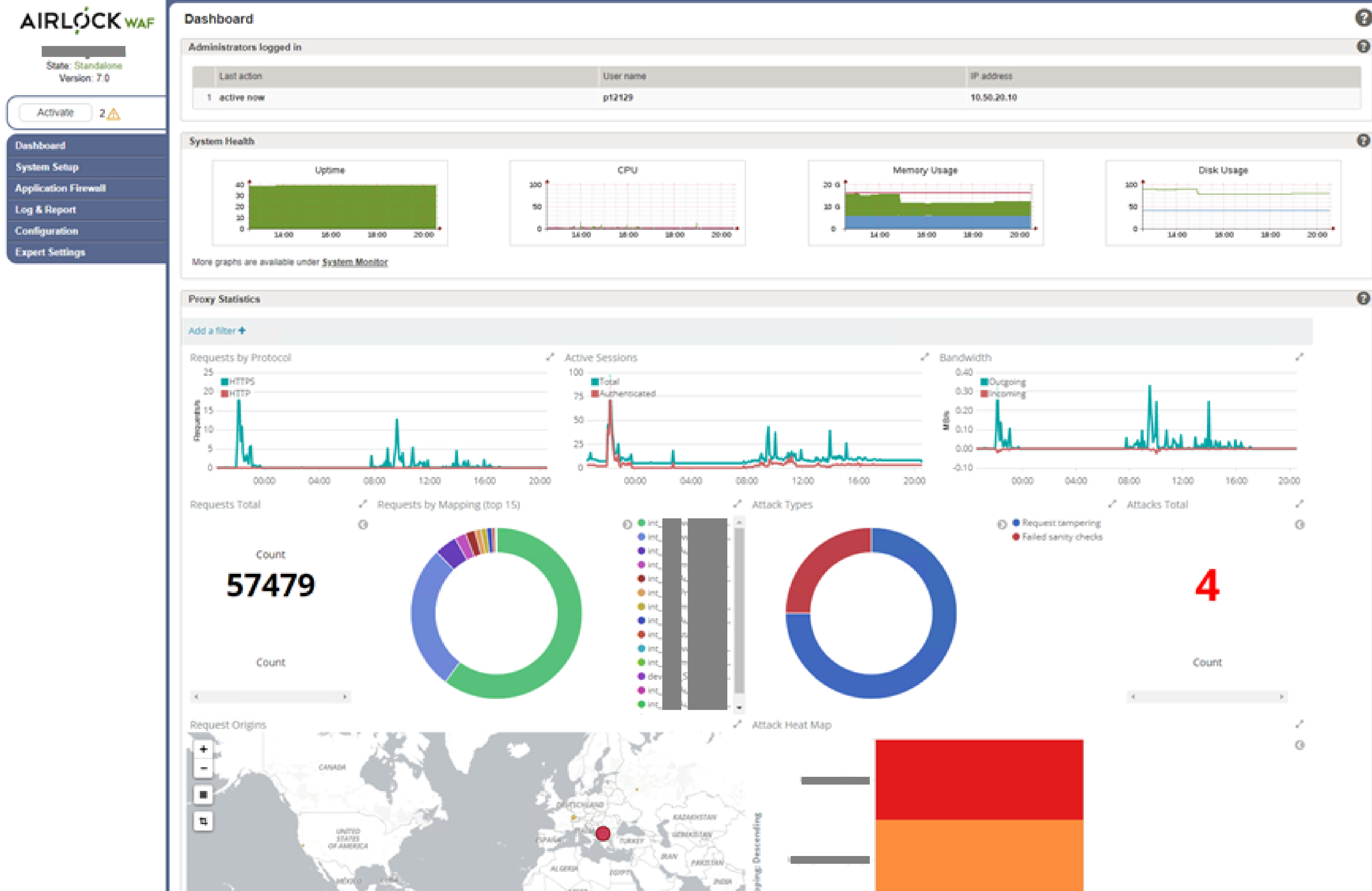
Web Application Firewalls ("WAF")



- Application-Layer Firewall zum Schutz eines oder mehreren Web-Server (Loadbalancer)
- Wird zusätzlich zum "normalen" Firewall verwendet (nicht als Ersatz)
- Schutz gegen SQL-Injection, XSS, usw. (z.B. OWASP Top 10)
- Je nach Produkt
 - kann als Bridge, Router, Reverse Proxy oder auf dem Server selber installiert werden
 - kann als Blacklist ("negative security model") oder Whitelist ("positive security model") konfiguriert werden
 - Validierung von Cookies, Session State, User, usw.
- Pro-aktive Schutz gegen neue (ev. noch nicht entdeckte) Sicherheitslücken möglich

Nachteile / Probleme

- Konfigurationsaufwand
 - Insbesondere bei der Erstellung einer Whitelist
 - Bei jedem Applikations-Release muss ggf. die Konfiguration angepasst werden
- Know How-Transfer vom Software-Entwickler zum → Firewall Administrator
- Herausforderungen
 - False negatives (bekannte Angriffsmethoden werden nicht erkannt)
 - False positives



Airlock WAF

Mappings definieren den Weg des Traffics vom "internet-facing" Server bis zum Backend-Host

AIRLOCK WAF

State: Standalone
Version: 7.0

Activate 2 ⚠

Dashboard

System Setup

Application Firewall

Reverse Proxy

Policy Learning

Geolocation Filter

SSL VPN

Certificates

Session

Default Actions

Deny Rules

Error Pages

Log & Report

Configuration

Expert Settings

p12129 | Change Password | Logout

Reverse Proxy

Filter labels

Hide unconnected items

Reset

Search

Virtual Host	Mapping	Back-end Group
beratung-int	dev_Secmail_Testsystem	dev_int_BEG
login-int	int_Auth-API_AirlockIAM_Authentication	dev_CsC_Services_auth-BEG
login-int	int_Auth-API_AirlockIAM_Authenticatio	devint_Medusa_New_App
my-int	int_Auth-API_Device-Activate-Kobil	devint_Medusa_New_App_direct_rm
my-int	int_Auth-API_Oauth-NewToken	devint_Medusa_New_App_HTTP_TEST
myguide-int	int_Auth-API_Oauth-NewToken_direct_..	int_Medusa
secmail	int_Auth-API_Oauth-Token	int_Medusa_direct_rm
services-int	int_Auth-API_Oauth-Token_direct_rm	int_CO5_https
static-int	int_Auth-API_Pin	int_CO5_https_direct_rm
static-int	int_Auth-API_Register	int_XML_Gateway_https
www-int-rm1	int_Auth-API_Revoke-Logout	int_XML_Gateway_https_direct_rm
www-int	int_Auth-API_Revoke-Logout_direct_rm	int_Kobil
www-int	int_Auth-API_User	int_Medusa_New_App
www-int	int_https	int_Medusa

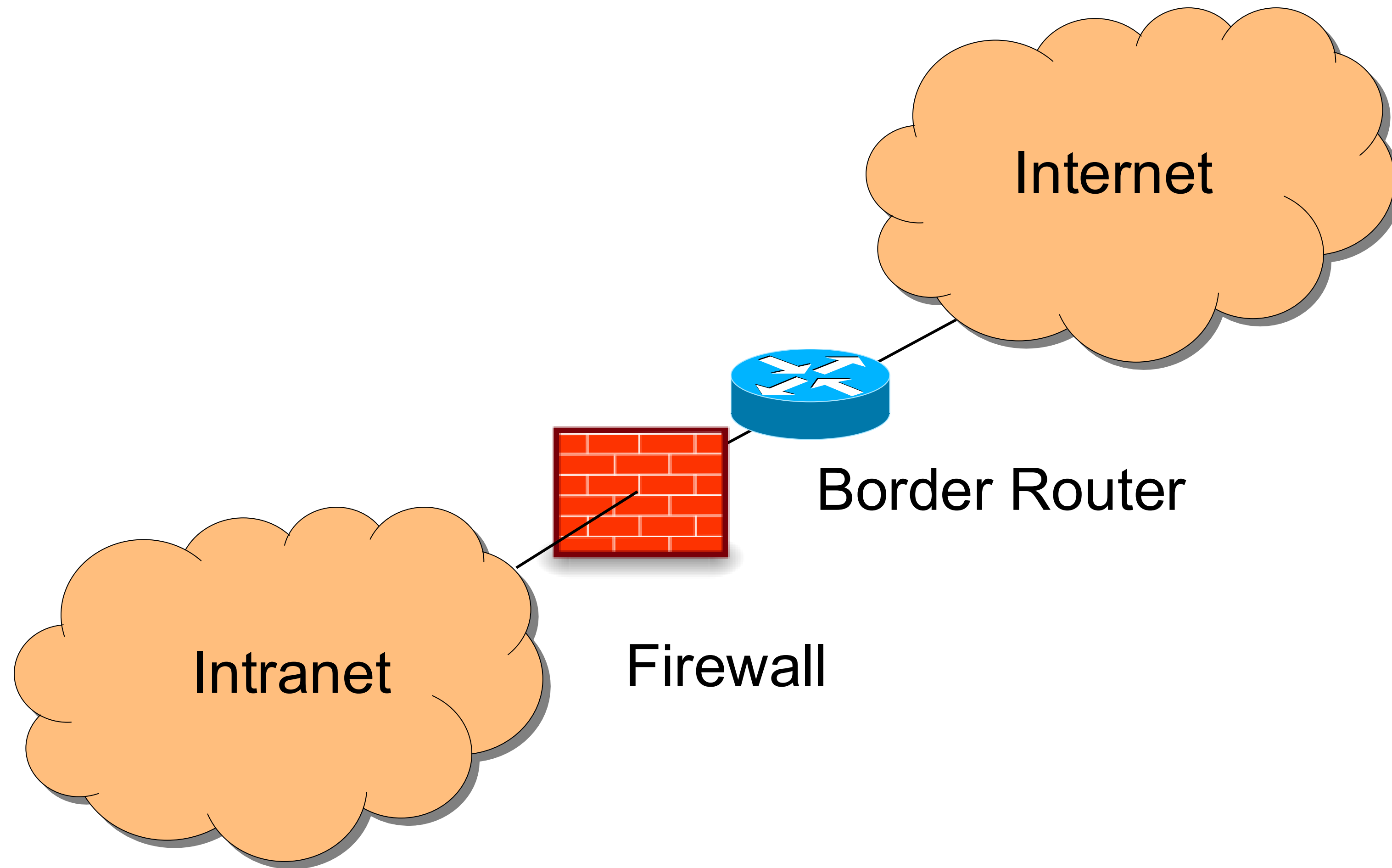
3. Firewall-Architekturen

DMZ → Demilitarisierte Zone

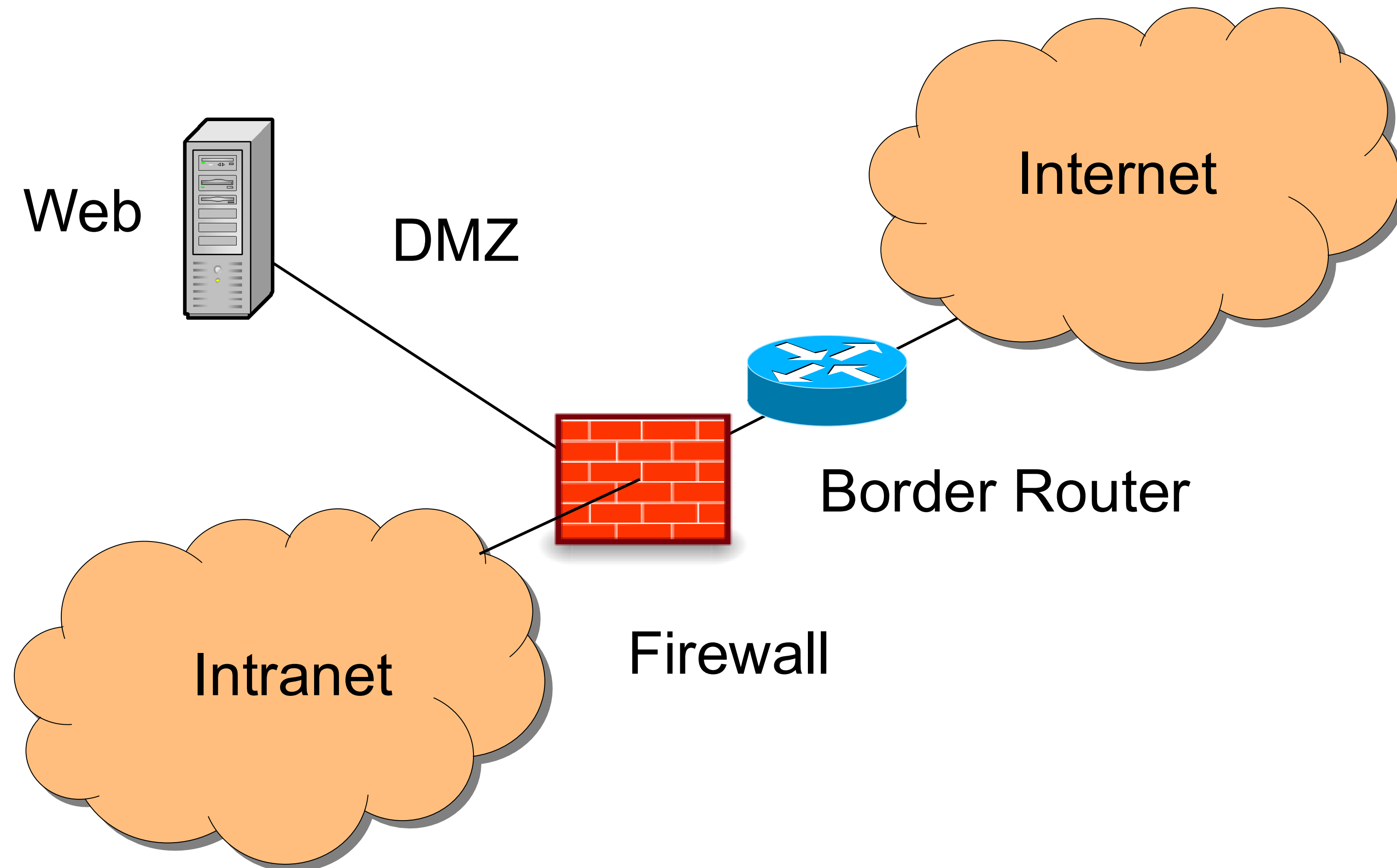
Einer der wichtigsten Begriffe im Zusammenhang mit Firewalls

- Heutzutage gibt es viele verschiedene Definitionen im Internet, einige davon sind jedoch falsch (oder zumindest verwirrend)
- "Klassische Definition": DMZ = Netzwerk zwischen dem geschützten Netzwerk (inside) und dem externen Netzwerk (outside)
- Systeme, die vom Internet her zugreifbar sind, sollten in der DMZ installiert werden.

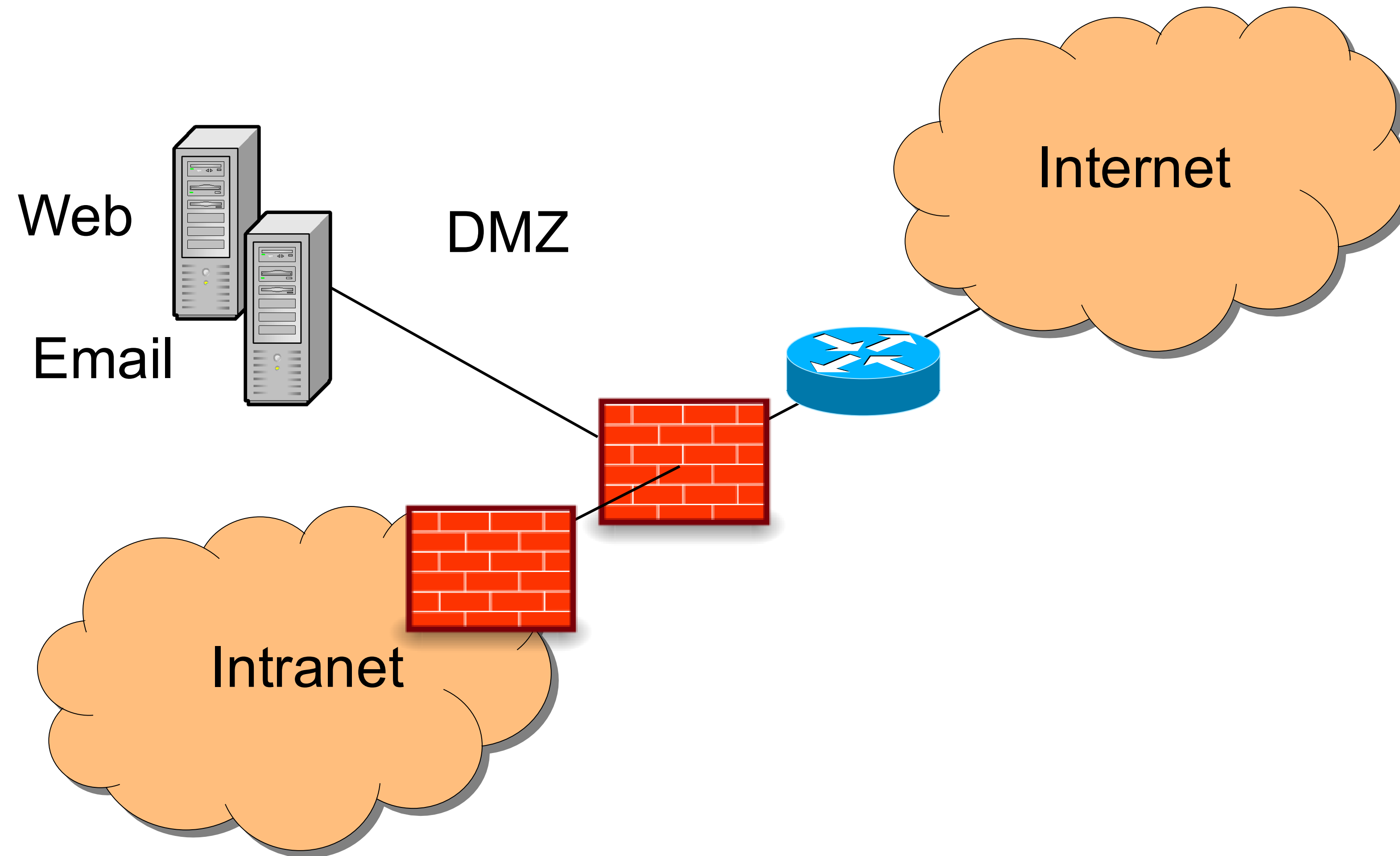
Einfache Internet-Verbindung ohne DMZ



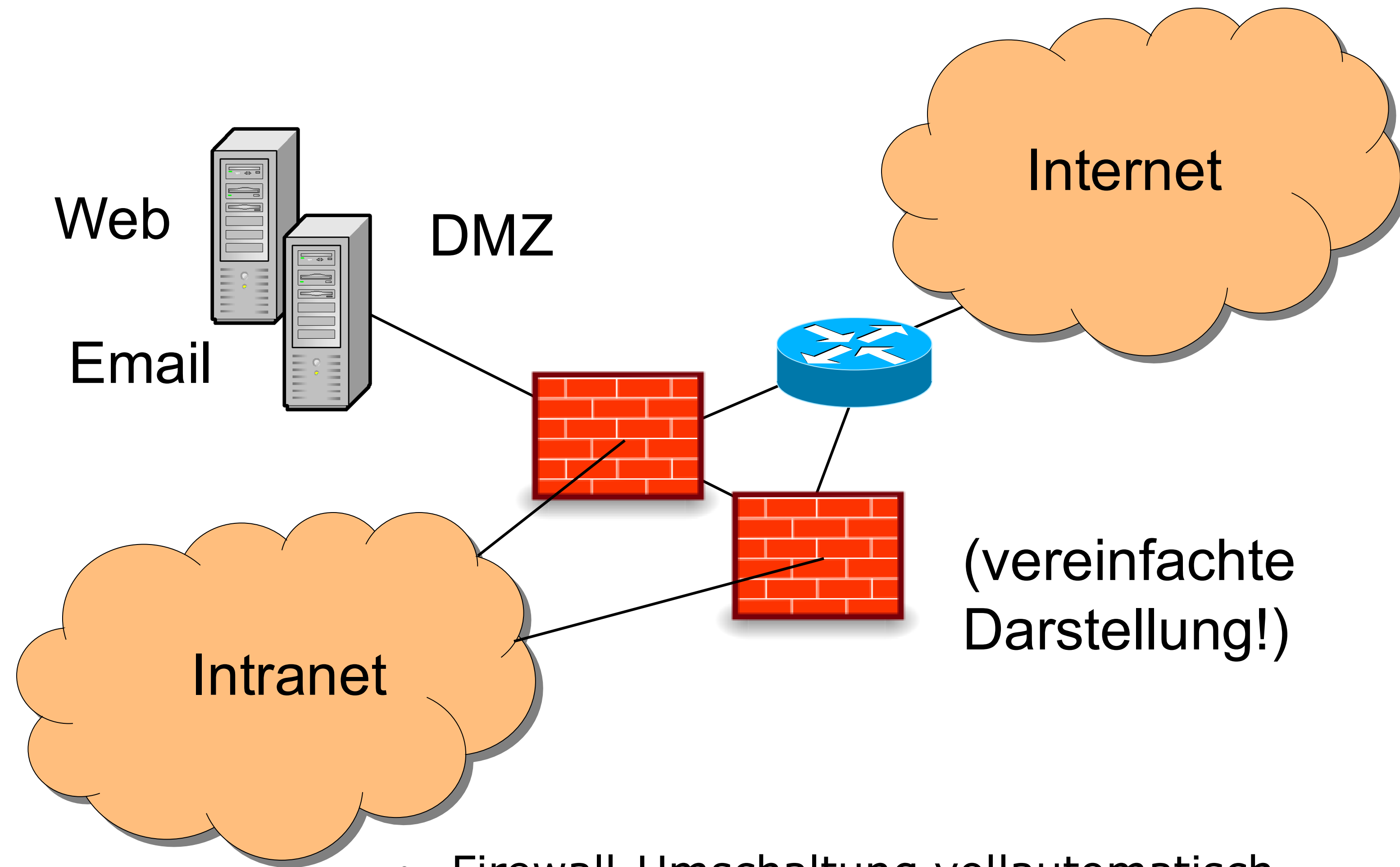
Einfache Internet-Verbindung mit DMZ



Hoch-Sicherheit

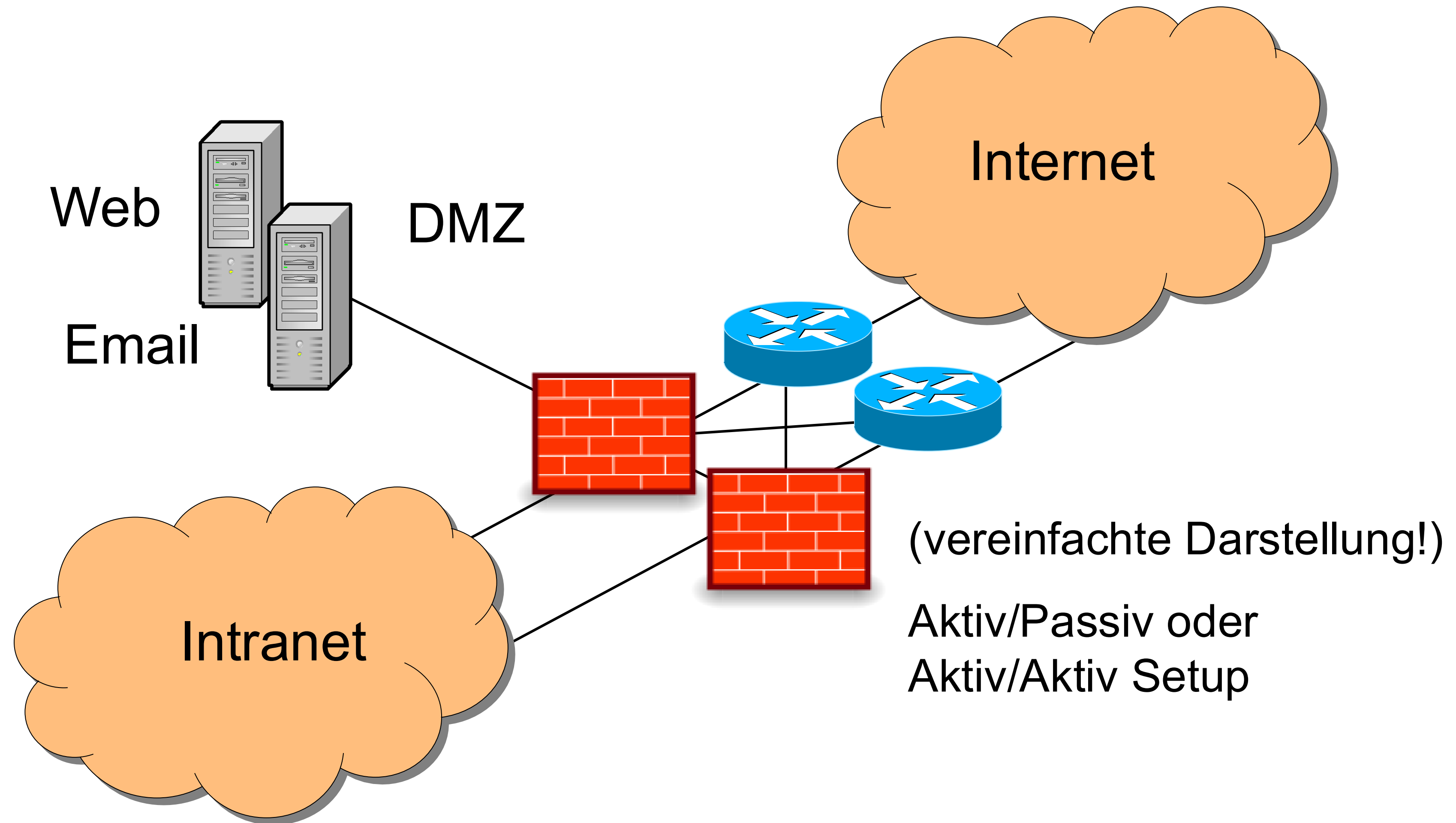


Hoch-Verfügbarkeit – Cluster (1)

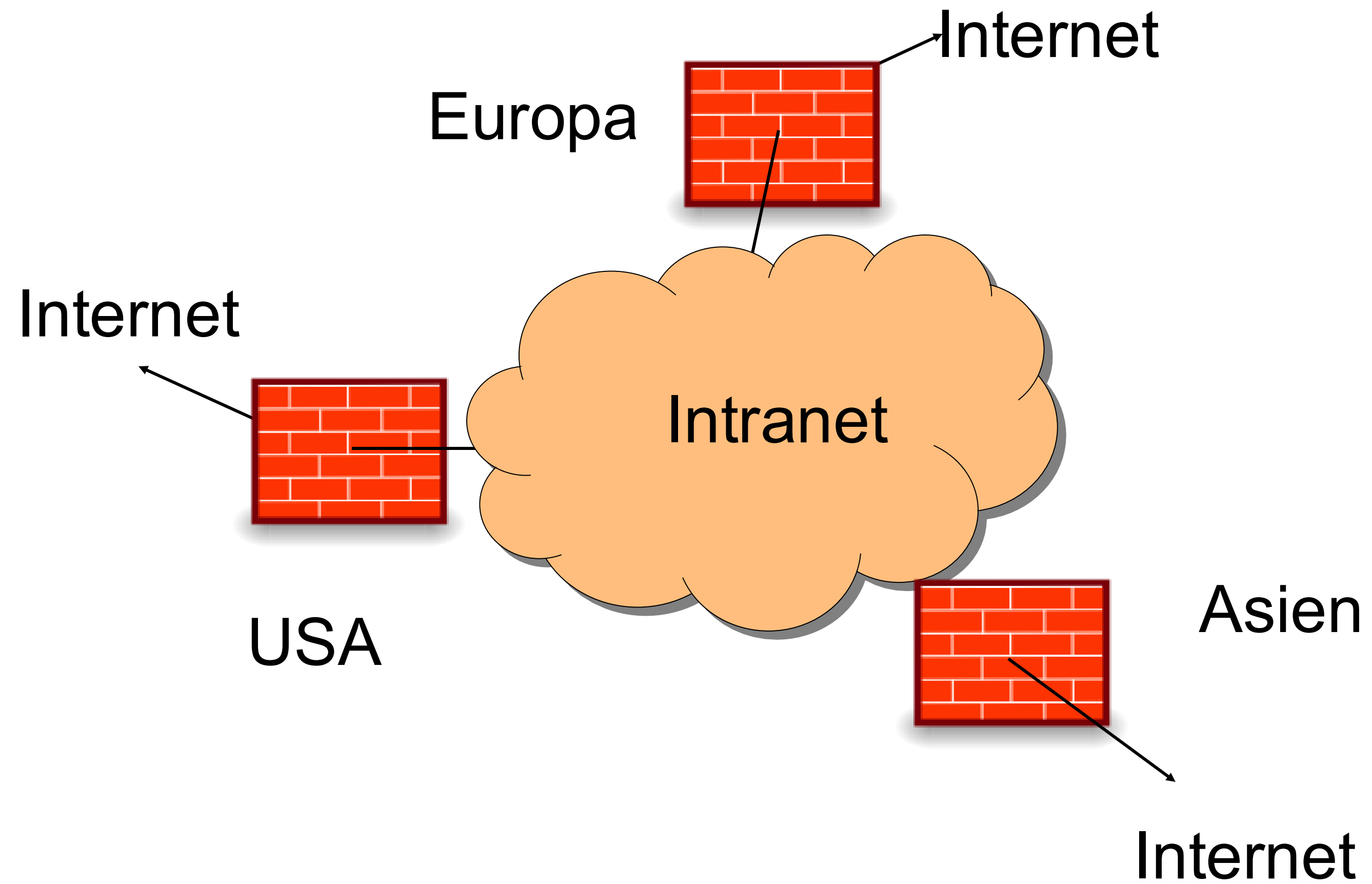


- Firewall-Umschaltung vollautomatisch
- Bestehende Verbindungen gehen NICHT verloren

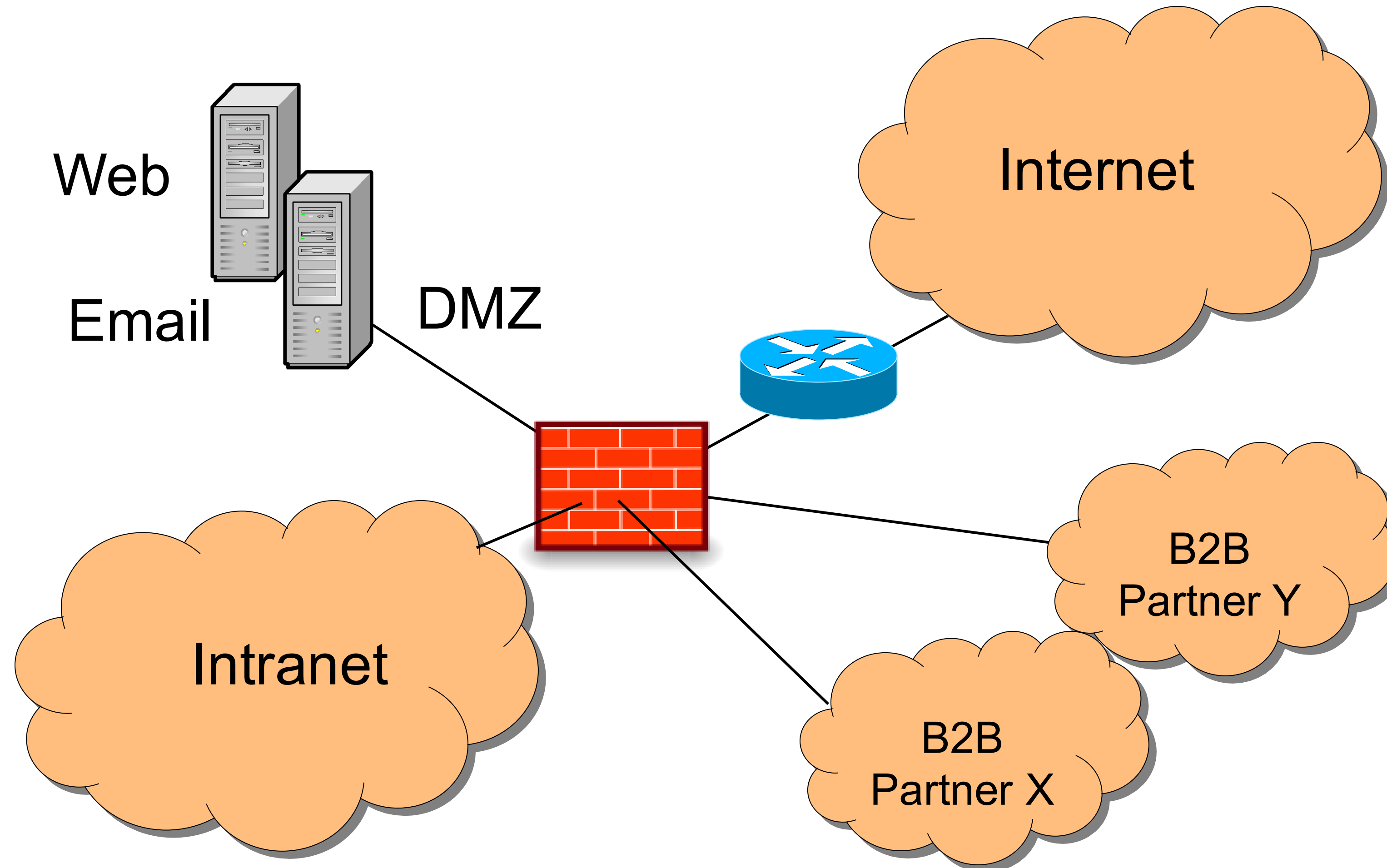
Hoch-Verfügbarkeit - Cluster (2)



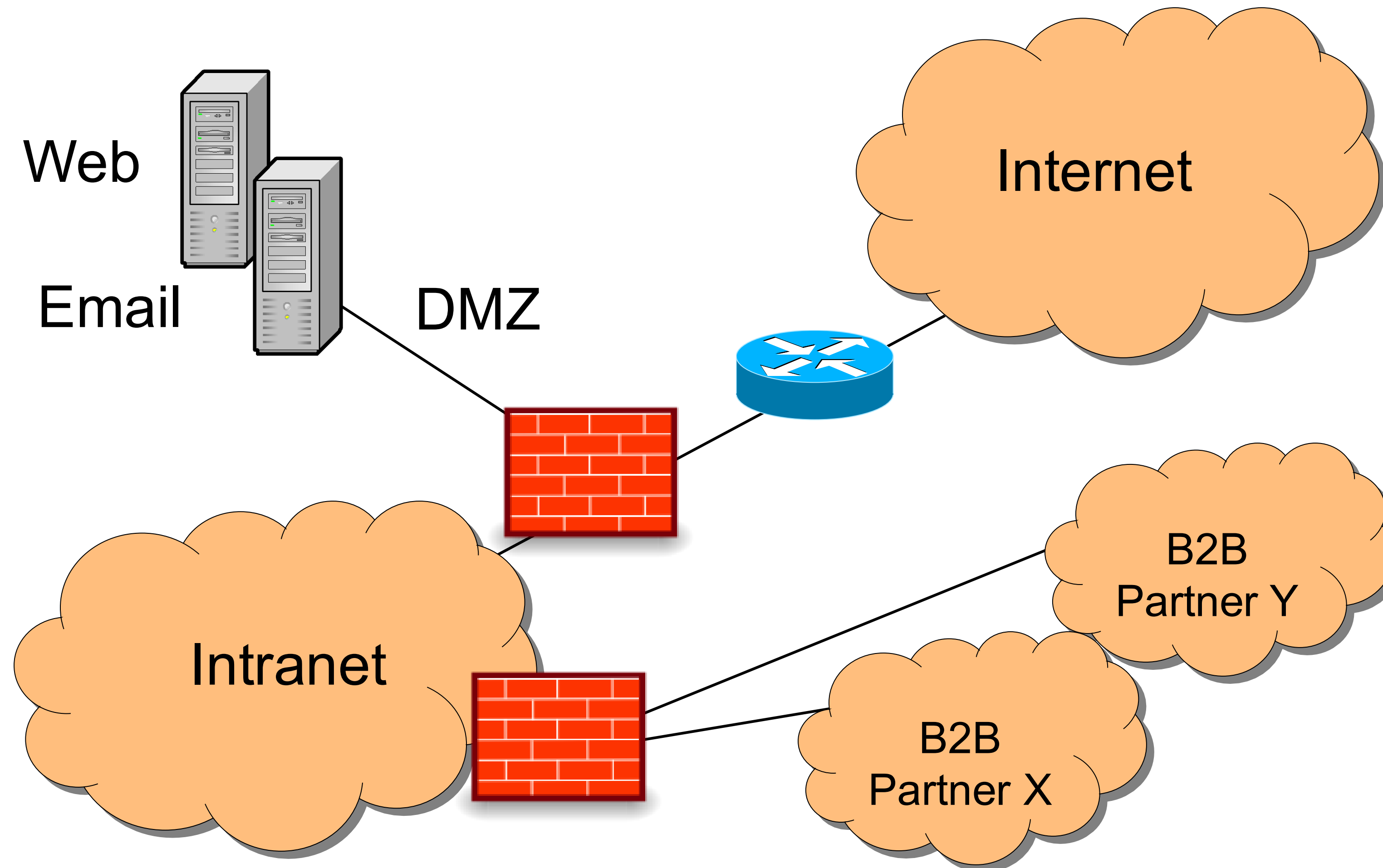
Multinationales / Interkontinentales Netz



Mehrere externe Netz-Verbindungen (1)

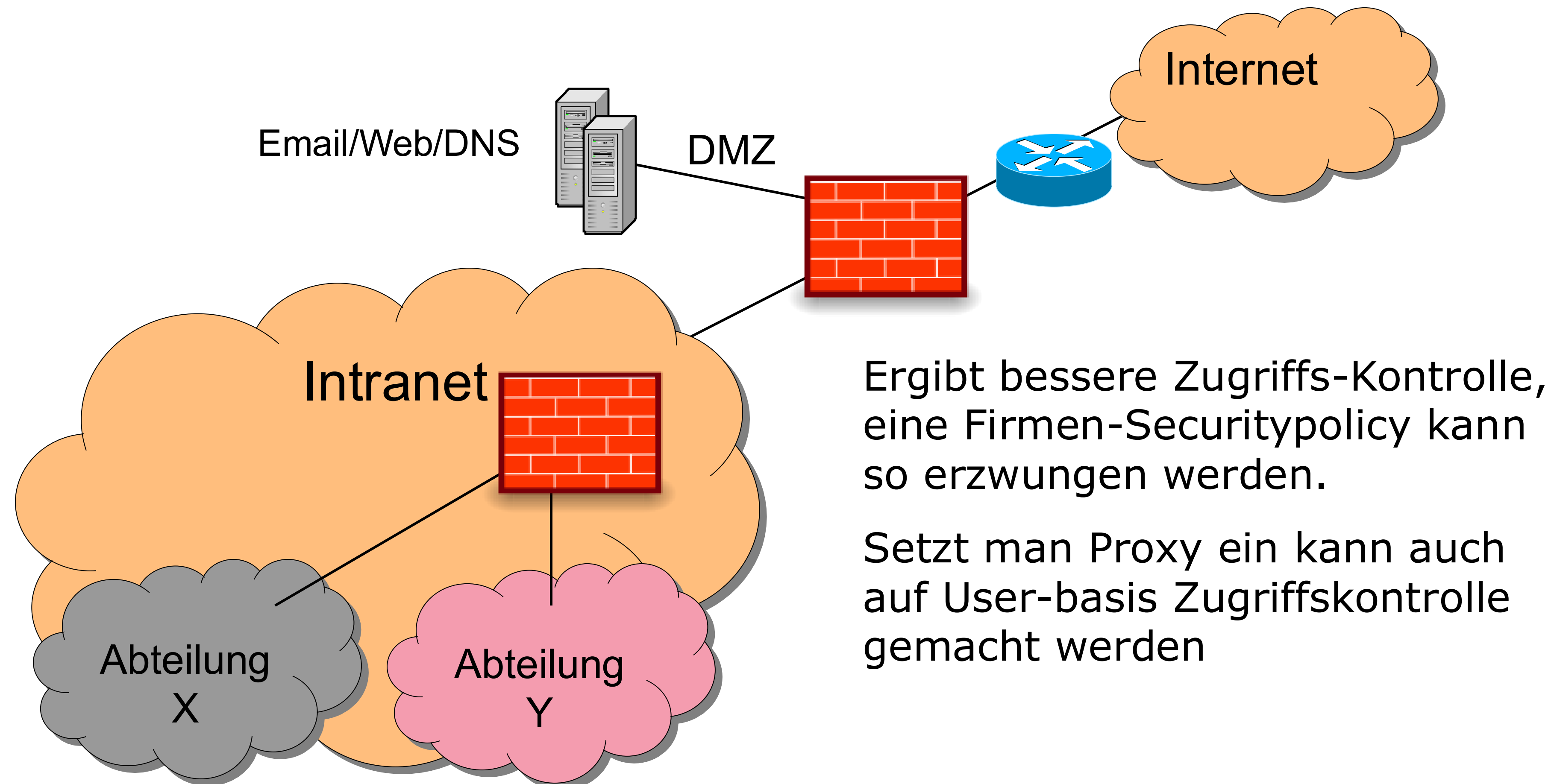


Mehrere externe Netz-Verbindungen (2)

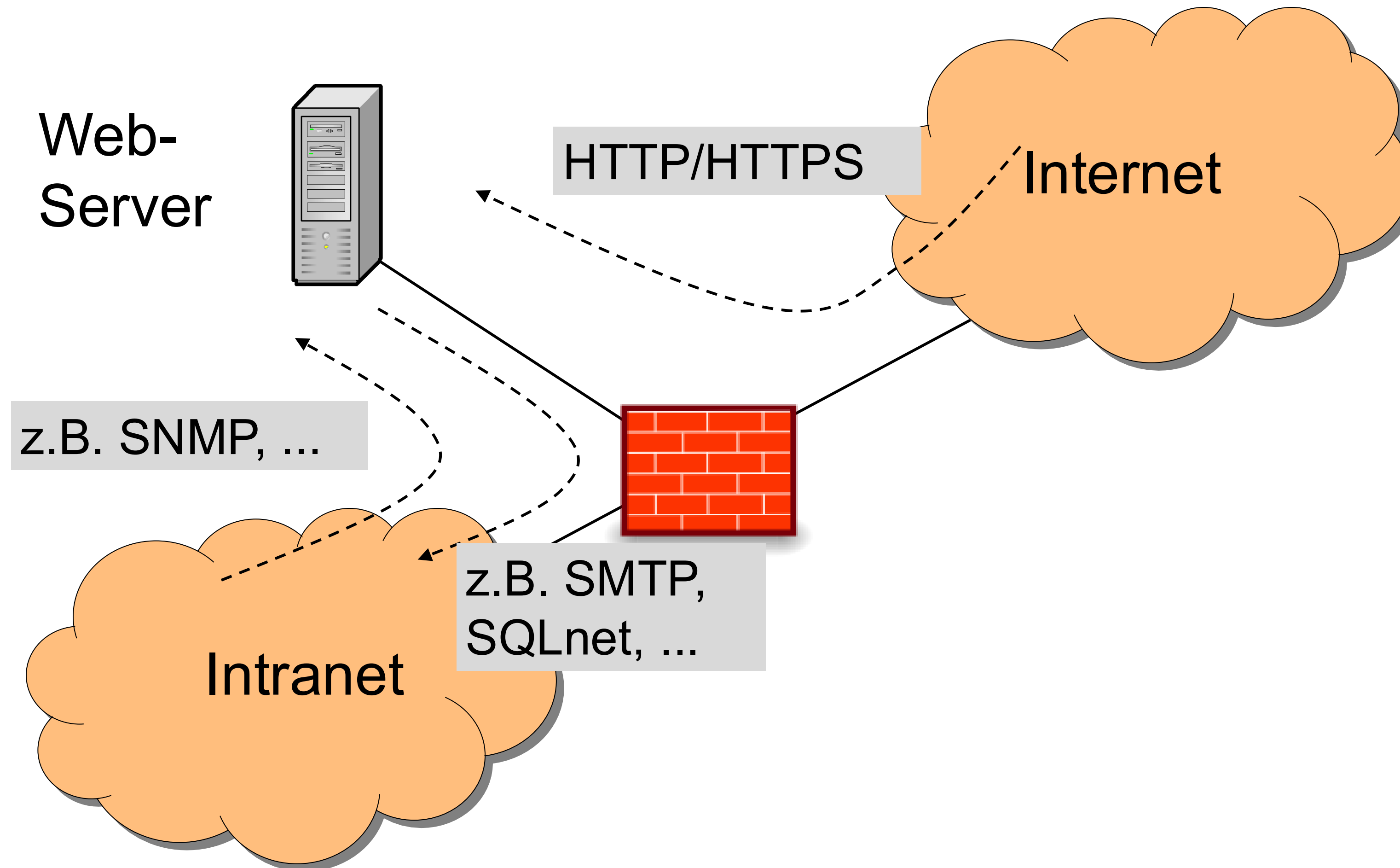


Wie sieht es mit Firma-internen FWs aus?

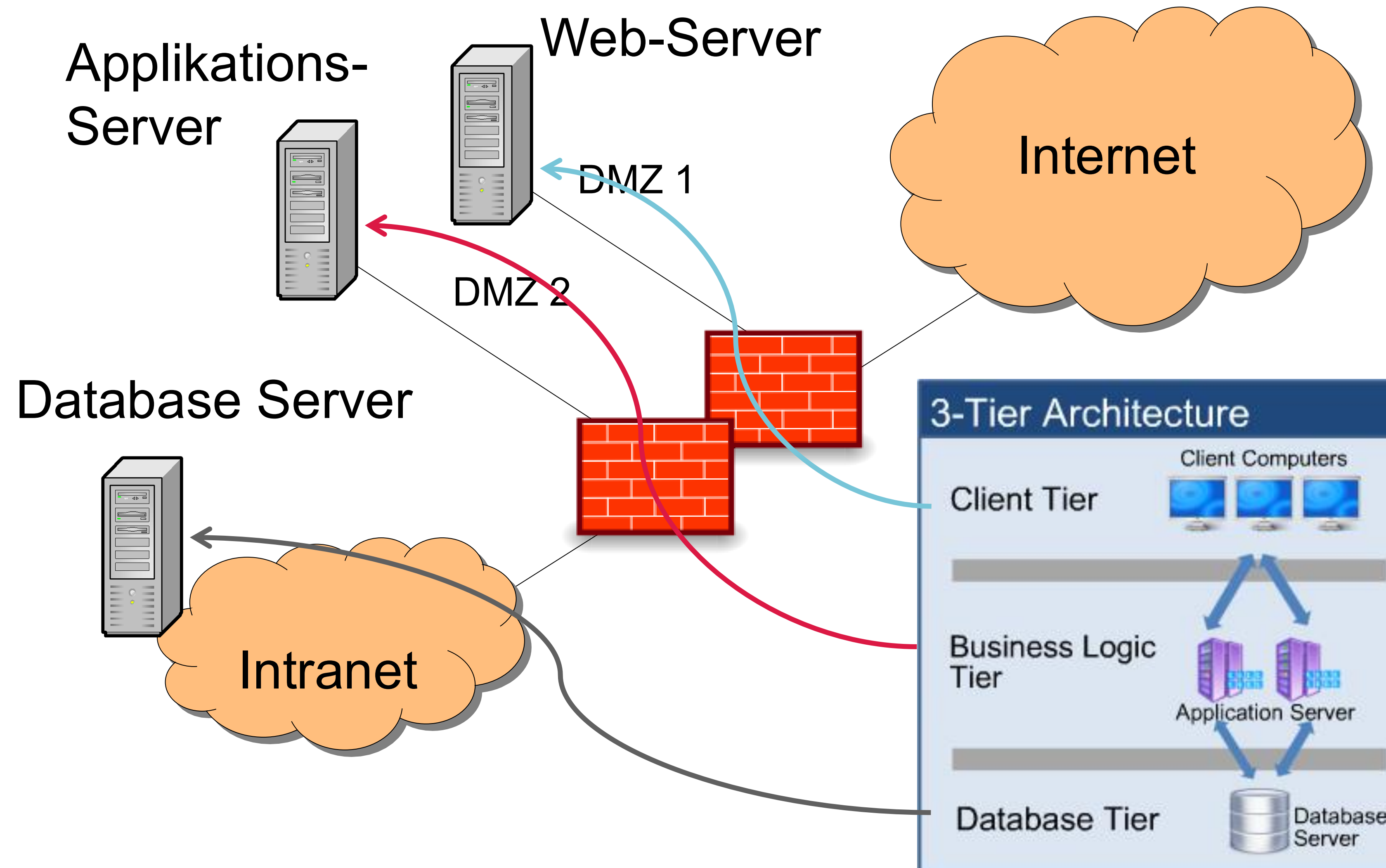
Segmentierung im Intranet nicht nur durch Router sondern auch durch FWs gemacht



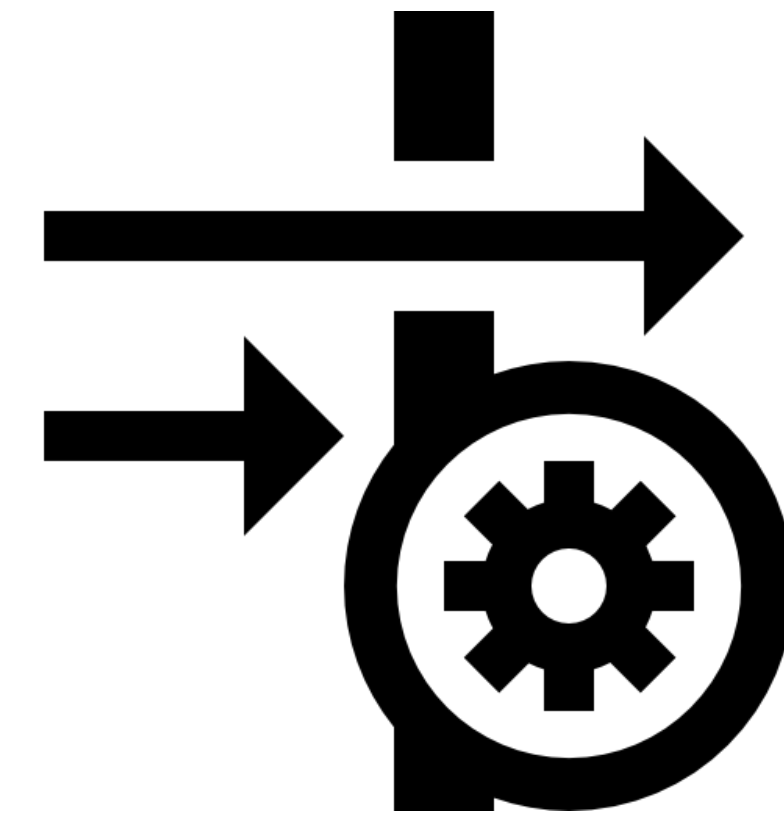
Web-Server: "einfache" Anwendung



Beispiel E-Commerce Lösung



Basics: Firewall Rules



1. Direkter Zugriff vom Internet ins interne Netz grundsätzlich verboten.
2. Öffentlich zugängliche Web- und sonstige Server gehören in eine DMZ – und NICHT ins interne Netz
3. Zugriff vom Internet aus begrenzt auf bestimmte Server in der DMZ. Anzahl Dienste (Ports) möglichst begrenzt.
4. **ALT:** Zugriff vom internen Netz auf das Internet grundsätzlich offen.
NEU: Zugriff vom internen Netz auf das Internet grundsätzlich untersagt (limitiert "phone home tools"!), ausser bestimmten Diensten oder über Proxies.
5. Gefährliche Protokolle nicht zulassen (soweit möglich), z.B. NetBIOS, NFS, TeamViewer, ...

4. Weitere Firewalls – Personal- und Linux-Firewalls

Firewalls Heute

- Alle Firewalls heute sind «Stateful»
- Application Gateways (Proxies) werden in spezifischen Szenarien eingesetzt
- Firewalls werden meistens als Appliance verkauft, basierend auf einem durch den Hersteller gehärteten Betriebssystem
- Zunehmend werden aber auch virtuelle Appliances eingesetzt.
- Bei privaten bzw. SOHO xDSL-Anbindungen wird meistens keine vollwertige Firewall eingesetzt. Die Sicherheit wird primär durch den *Einsatz von NAT* und nicht durch Firewall-Regeln realisiert.

Firewalls Heute

- Eine moderne Firewall muss bei der Beschaffung nicht mehr ein kostspieliges Unterfangen sein, da zahlreiche OS Firewall-Software erhältlich ist, wie z.B. pfSense, IPFire, OPNSense, etc.
- Zunehmend besitzen moderne Client-Betriebssysteme integrierte Firewall-Funktionalität, sogenannte Personal Firewalls wie z.B. Linux *iptables* oder *Windows Defender Firewall*



Personal Firewalls

- Eine "Personal Firewall" ist eine Software-Anwendung, die auf einem PC installiert wird und Sicherheitsfunktionen bereitstellt, um den PC vor unberechtigttem Zugriff von aussen zu schützen.
- Eine effektive "Personal Firewall" erlaubt Benutzern den Zugriff auf alle notwendigen Netzwerk- und Webressourcen, schützt den PC jedoch vor externen Attacken ("Hacking") und benachrichtigt den Benutzer beim Eindringen unberechtigter Benutzer.



Personal Firewalls

- Bietet Schutz beim direktem Anschluss ans Internet (z.B. Wireless) oder beim Anschluss an andere Netzwerke (z.B. Hotel)
- Werden oft als integrierter Bestandteil eines "Internet Security" Produkt gekauft (zusammen mit Anti-Viren-Software, usw.)
- Heutige Personal Firewalls bieten Schutz nicht nur von **ankommenden** Verbindungen sondern auch von **abgehenden**.

Kritikpunkte

- Schwierig zu konfigurieren: dürfen "services.exe" oder "winword.exe" auf das Internet zugreifen?
- Oft falsch konfiguriert oder funktionieren nicht richtig



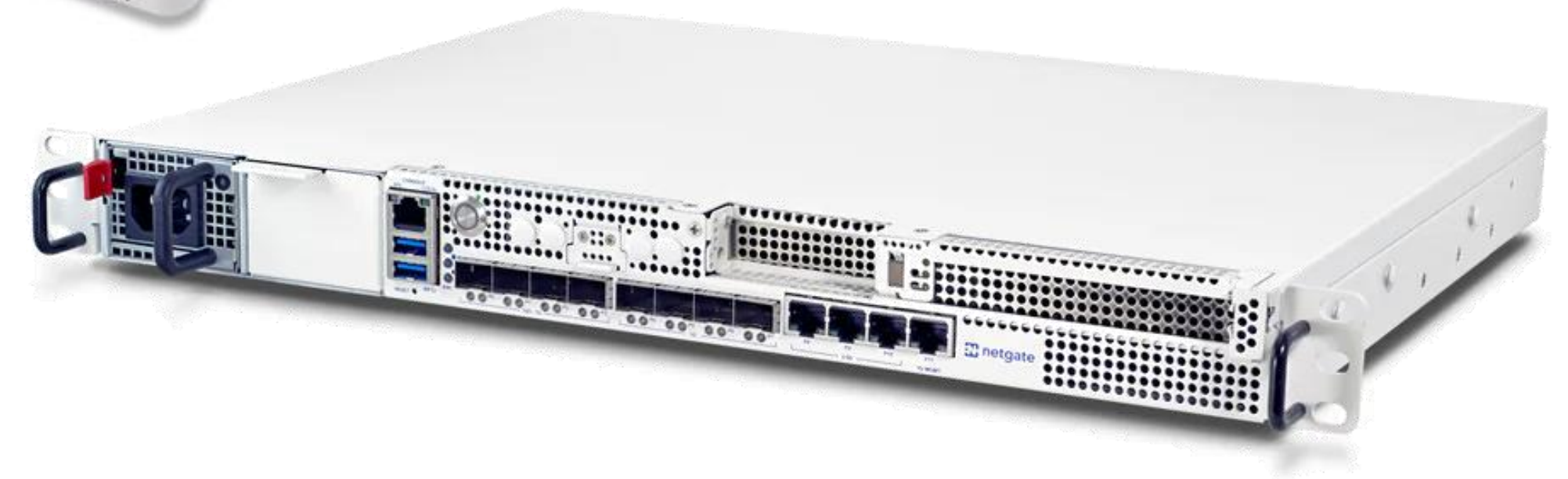
Windows 10/11-Firewall



- Stateful Packet Filtering
- Total überarbeitet im Vergleich zu früheren Windows Versionen
 - Neu: Konfiguration von ausgehenden Regeln
 - Integration in Active Directory
 - Mehrere Profile
 - Relativ komplexe Regeln können definiert werden
 - z.B. Zugriff von telnet.exe auf 192.168.1.14 ist nicht zugelassen
- Viele Regeln standardmässig konfiguriert, mit Unterscheidung zwischen Public / Domain / Private
- Vorsicht: Standardmässig ist abgehende Verkehr weitgehend zugelassen (Vermeidung von zu vielen Warnmeldungen)



- Frei verfügbare Software (Open Source)
- Läuft primär auf embedded Systemen, z.B. PCEngines (ALIX Boards)
- Bietet typische Basisfunktionalität für kleinere Umgebungen an wie z.B: VPN, NAT, DHCP Server, DNS Forwarder usw.
- Bietet auch erweiterte Funktionalität für professionelle Umgebungen an, wie z.B. Hochverfügbarkeit, Lastverteilung
- Siehe <https://www.pfsense.org/>



Linux Netfilter/Iptables



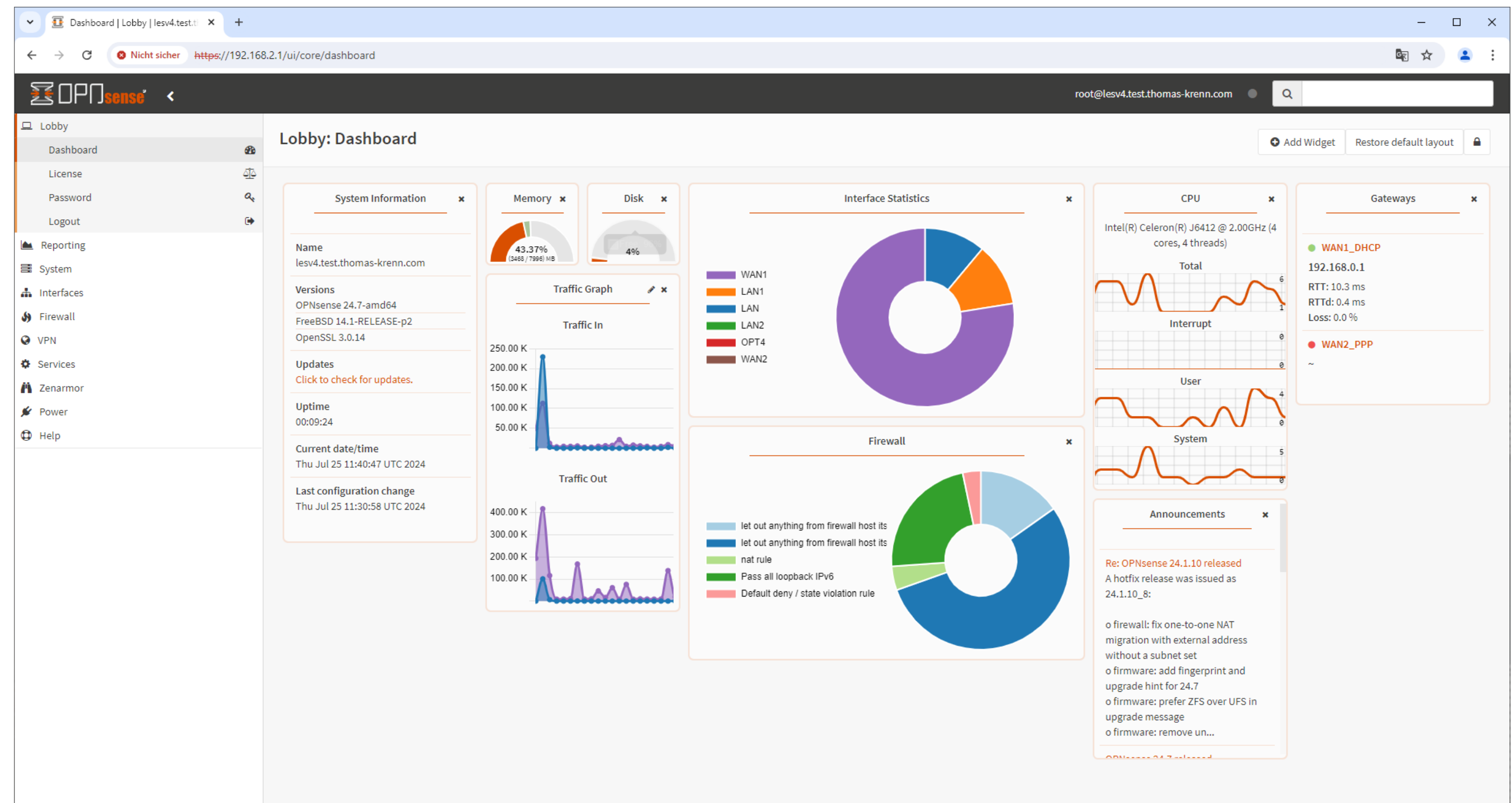
- Listen von Regeln in der Form von "Chains", z.B.
 - FORWARD (für Pakete die nicht an die Firewall adressiert sind)
 - INPUT (für Pakete adressiert an die Firewall)
 - OUTPUT (für Pakete erzeugt von der Firewall)
- Weitere "Chains" können erzeugt und konfiguriert werden
- Konfiguration via grafische Oberfläche oder Command Line:
 - `iptables -N` Create new chain
 - `iptables -L` List rules in chain
 - `iptables -A` Append rules to chain
 - usw.
- Beispiel

Allow passive FTP transfers:

```
iptables -A INPUT -i eth0 -p tcp -s 0/0 -sport 1024:65535 --dport 1024:65535 -m state -state ESTABLISHED,RELATED -j ACCEPT
```

OPNsense

- Semi-professionelle Firewall
- Open source
- Umfangreicher Funktionsumfang
- Virtuell und klassisch (self made Appliance) verfügbar
- <https://opnsense.org>



OPNsense®
Securing networks made easy